GUÍA TÉCNICA COLOMBIANA

GTC-ISO/IEC 27005:2022

Seguridad de la información, ciberseguridad y protección de la privacidad. Orientaciones sobre la gestión de los riesgos para la seguridad de la información

E: Information security, cybersecurity and privacy protection. Guidance on managing information security risks

CORRESPONDENCIA: esta Guía Técnica Colombiana es una adopción idéntica (IDT) por traducción de la norma ISO/IEC 27005:2022, Edición 4.0 y está cubierta por los derechos de autor y otros derechos de propiedad intelectual de IEC, según el acuerdo de licencia con esta entidad

DESCRIPTORES: evaluación de riesgos; tratamiento del riesgo; SGSI

I.C.S.: 35.030

® ICONTEC 2023

Reservados todos los derechos. Ninguna parte de esta publicación puede ser reproducida o utilizada en cualquier forma o por cualquier medio, electrónico o mecánico incluyendo fotocopiado y microfilmación, sin permiso por escrito del editor.

Editada por ICONTEC. Bogotá, D.C. Tel. (57) (601) 5806419

Edición 4.0

Prohibida su reproducción | Editada 2023-12-06

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

PRÓLOGO

El Instituto Colombiano de Normas Técnicas y Certificación (ICONTEC) es el organismo nacional de normalización, según el Decreto 1595 de 2015.

ICONTEC es una entidad de carácter privado, sin ánimo de lucro, cuya Misión es fundamental para brindar soporte y desarrollo al productor y protección al consumidor. Colabora con el sector gubernamental y apoya al sector privado del país, para lograr ventajas competitivas en los mercados interno y externo.

La representación de todos los sectores involucrados en el proceso de Normalización Técnica está garantizada por los Comités Técnicos y el período de Consulta Pública, este último caracterizado por la participación del público en general.

Se llama la atención sobre la posibilidad de que algunos elementos de este documento pueden ser objeto de derechos de patente. ICONTEC no asume la responsabilidad por la identificación de dichas patentes, o por la documentación que se haya aportado que goza de esta protección legal.

La GTC-ISO/IEC 27005:2023 fue estudiada por el CTN 181 - Gestión de la tecnología de la información, y ratificada por el Consejo Directivo de 2023-12-06.

Este documento está sujeto a ser revisado en cualquier momento con el objeto de que responda a las necesidades y exigencias actuales. Se invita a los usuarios de este documento a presentar sus solicitudes de revisión a ICONTEC; sus comentarios serán puestos a consideración del comité técnico responsable del estudio de este tema.

ICONTEC cuenta con un Centro de Información que pone a disposición de los interesados normas internacionales, regionales y nacionales y otros documentos relacionados.

DIRECCIÓN DE NORMALIZACIÓN

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

CONTENIDO

INTRODUCCIÓN I

1. OBJETO Y CAMPO DE APLICACIÓN 1

2. REFERENCIAS NORMATIVAS 1

3. TÉRMINOS Y DEFINICIONES 1

3.1 Términos relacionados con el riesgo para la seguridad de la información 1

3.2 Términos relacionados con la gestión de riesgos para la seguridad de la información 5

4 ESTRUCTURA DEL DOCUMENTO 7

5 GESTIÓN DE RIESGOS PARA LA SEGURIDAD DE LA INFORMACIÓN 8

5.1 Proceso de gestión de riesgos para la seguridad de la información 8

5.2 Ciclos de gestión de los riesgos para la seguridad de la información 9

6 ESTABLECIMIENTO DEL CONTEXTO 10

6.1 Consideraciones organizativas 10

6.2 Identificación de los requisitos básicos de las partes interesadas 10

6.3 Aplicación de la evaluación del riesgo 11

6.4 Establecer y mantener criterios de riesgo para la seguridad de la información 11

6.5 Elección de un método adecuado 17

7 PROCESO DE EVALUACIÓN DE RIESGOS PARA LA SEGURIDAD DE LA INFORMACIÓN 18

7.1 Generalidades 18

7.2 Identificación de los riesgos para la seguridad de la información 19

7.3 Análisis de los riesgos para la seguridad de la información 22

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

7.4 Valoración de los riesgos para la seguridad de la información 26

8 PROCESO DE TRATAMIENTO DEL RIESGO PARA LA SEGURIDAD DE LA INFORMACIÓN 28

8.1 Generalidades 28

8.2 Selección de las opciones adecuadas de tratamiento del riesgo para la seguridad de la información 28

8.3 Determinación de todos los controles necesarios para aplicar las opciones de tratamiento del riesgo para la seguridad de la información 29

8.4 Comparación de los controles determinados con los del Anexo A de la NTC-ISO/IEC 27001:2022 32

8.5 Elaboración de una declaración de aplicabilidad 33

8.6 Plan de tratamiento del riesgo para la seguridad de la información 34

9 OPERACIÓN 37

9.1 Ejecución del proceso de evaluación de riesgos para la seguridad de la información 37

9.2 Ejecución del proceso de tratamiento del riesgo para la seguridad de la información 38

10 APROVECHAMIENTO DE LOS PROCESOS RELACIONADOS CON EL SGSI 38

10.1 Contexto de la organización 38

10.2 Liderazgo y compromiso 40

10.3 Comunicación y consulta 40

10.4 Información documentada 42

10.5 Seguimiento y revisión 44

10.6 Revisión de la gestión 47

10.7 Acción correctiva 47

10.8 Mejora continua 48

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

ANEXO A (Informativo) EJEMPLOS DE TÉCNICAS DE APOYO AL PROCESO DE EVALUACIÓN DE RIESGOS 50

BIBLIOGRAFÍA 74

DOCUMENTO DE REFERENCIA 75

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

INTRODUCCIÓN

Este documento proporciona orientaciones sobre:

- La implementación de los requisitos en materia de riesgos para la seguridad de la información especificados en la NTC-ISO/IEC 27001.
- Las referencias básicas entre de las normas desarrolladas por el comité ISO/IEC JTC 1/SC 27 para apoyar las actividades de gestión de riesgos para la seguridad de la información.
- Las acciones que se ocupan de los riesgos para la seguridad de la información (véase la NTC-ISO/IEC 27001:2022, numerales 6.1 y 8).
- La implementación de la orientación para gestión de riesgos de la NTC-ISO 31000 en el contexto de la seguridad de la información.

Este documento contiene orientaciones detalladas sobre la gestión de riesgos y complementa las orientaciones de la GTC-ISO/IEC 27003.

Este documento está diseñado para ser usado por:

- Organizaciones que pretendan establecer e implementar un sistema de gestión de la seguridad de la información (SGSI) de conformidad con lo dispuesto en la NTC-ISO/IEC 27001.
- Personas que se encargan de o participan en la gestión de riesgos para la seguridad de la información (por ejemplo, profesionales en SGSI, propietarios del riesgo y otras partes interesadas).
- Organizaciones que pretendan mejorar su proceso de gestión de riesgos para la seguridad de la información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

SEGURIDAD DE LA INFORMACIÓN, CIBERSEGURIDAD Y PROTECCIÓN DE LA PRIVACIDAD. ORIENTACIONES SOBRE LA GESTIÓN DE LOS RIESGOS PARA LA SEGURIDAD DE LA INFORMACIÓN

1. OBJETO Y CAMPO DE APLICACIÓN

Este documento proporciona orientaciones para ayudar a las organizaciones a:

- Cumplir con los requisitos de la NTC-ISO/IEC 27001 relativos a las acciones para abordar los riesgos para la seguridad de la información.
- Realizar actividades de gestión de riesgos para la seguridad de la información, específicamente la evaluación y el tratamiento del riesgo para la seguridad de la información.

Este documento es aplicable a todas las organizaciones, independientemente de su tipo, tamaño o sector.

2. REFERENCIAS NORMATIVAS

Los siguientes documentos normativos se referencian en el texto de tal manera que parte o la totalidad de su contenido constituye requisitos para este documento. Para las referencias fechadas, se aplica únicamente la edición citada. Para referencias no fechadas, se aplica la última edición del documento referenciado (incluida cualquier corrección).

NTC-ISO/IEC 27000, Tecnología de la información. Técnicas de seguridad. Sistemas de gestión de la seguridad de la información. Visión general y vocabulario.

3. TÉRMINOS Y DEFINICIONES

Para los propósitos de este documento, se aplican los términos y definiciones que figuran en las normas ISO/TR 27000 y los siguientes.

La ISO y la IEC mantienen bases de datos terminológicas para su uso en la normalización en las siguientes direcciones:

- Plataforma de navegación en línea de la norma ISO: disponible en https://www.iso.org/obp
- IEC Electropedia: disponible en https://www.electropedia.org/

3.1 Términos relacionados con el riesgo para la seguridad de la información

3.1.1 contexto externo (*external context*). Entorno externo en el que la organización pretende alcanzar sus objetivos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Nota 1 a la entrada: el contexto externo puede abarcar lo siguiente:

- El entorno social, cultural, político, legal, regulatorio, financiero, tecnológico, económico y geológico, ya sea internacional, nacional, regional o local.
- Los principales impulsores y las tendencias que afectan a los objetivos de la organización.
- Las relaciones, percepciones, valores, necesidades y expectativas de las partes interesadas externas.
- Las relaciones y compromisos contractuales.
- La complejidad de las redes y las dependencias.

[FUENTE: Guía ISO 73:2009, 3.3.1.1; modificada: se modificó la Nota 1 a la entrada].

3.1.2 contexto interno (*internal context*). Entorno interno en el que la organización busca alcanzar sus objetivos.

Nota 1 a la entrada: el contexto interno puede abarcar:

- La visión, la misión y los valores.
- La gobernanza, la estructura organizativa, los roles y la responsabilidad de rendición de cuentas.
- La estrategia objetivos y políticas.
- La cultura organizacional.
- Las normas, directrices y modelos adoptados por la organización.
- Las capacidades, entendidas en términos de recursos y conocimiento (por ejemplo, capital, tiempo, personas, procesos, sistemas y tecnologías).
- Los datos, los sistemas de información y los flujos de información.
- Las relaciones con las partes interesadas internas, en las que se toman en consideración sus percepciones y valores.
- Las relaciones y compromisos contractuales.
- Las interdependencias e interconexiones internas.

[FUENTE: Guía ISO 73:2009, 3.3.1.2; modificada: se modificó la Nota 1 a la entrada].

3.1.3 riesgo (*risk*). Efecto de la incertidumbre sobre los objetivos.

Nota 1 a la entrada: un efecto es una desviación de lo esperado, ya sea positiva o negativa.

Nota 2 a la entrada: los objetivos pueden tener diferentes aspectos y categorías, y pueden aplicarse a diversos niveles.

Nota 3 a la entrada: la incertidumbre es el estado, incluso parcial, de carencia de información relacionada con la comprensión o el conocimiento sobre un evento (véase el numeral 3.1.11), su consecuencia (véase el numeral 3.1.14) o su probabilidad (véase el numeral 3.1.13).

Nota 4 a la entrada: el riesgo suele expresarse en términos de fuentes de riesgo (véase el numeral 3.1.6), eventos potenciales, sus consecuencias y su probabilidad.

Nota 5 a la entrada: en el ámbito de los sistemas de gestión de la seguridad de la información, los riesgos para la seguridad de la información se pueden expresar como el efecto de la incertidumbre sobre los objetivos de seguridad de la información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Nota 6 a la entrada: los riesgos para la seguridad de la información generalmente se asocian con un efecto negativo de la incertidumbre sobre los objetivos de seguridad de la información.

Nota 7 a la entrada: los riesgos para la seguridad de la información se pueden asociar con el potencial de que las amenazas (véase el numeral 3.1.9) se aprovechen de las vulnerabilidades (véase el numeral 3.1.10) de un activo de información o de un grupo de activos de información, y, por lo tanto, causen daño a una organización.

[FUENTE: ISO 31000:2018, 3.1; modificada: la frase: “Puede ser positiva, negativa o ambas, y puede abordar, crear o generar oportunidades y amenazas” se sustituyó por “positiva o negativa” en la Nota 1 a la entrada; la Nota 3 a la entrada original se renumeró como Nota 4 a la entrada, y se agregaron las Notas 3, 5, 6 y 7 a la entrada].

3.1.4 escenario de riesgo (*risk scenario*). Secuencia o combinación de eventos (véase el numeral 3.1.11) que llevan desde la causa inicial hasta la consecuencia no deseada (véase el numeral 3.1.14).

[FUENTE: ISO 17666:2016, 3.1.13; modificada: se eliminó la Nota 1 a la entrada].

3.1.5 propietario del riesgo (*risk owner*). Persona o entidad con la responsabilidad de rendir cuentas y la autoridad para gestionar un riesgo (véase el numeral 3.1.3).

[FUENTE: Guía ISO 73:2009, 3.5.1.5]

3.1.6 fuente de riesgo (*risk source*). Elemento que, por sí solo o en combinación con otros, tiene el potencial de generar riesgo (véase el numeral 3.1.3).

Nota 1 a la entrada: una fuente de riesgo puede ser de uno de estos tres tipos:

- Humana.
- Ambiental.
- Técnica.

Nota 2 a la entrada: un tipo de fuente de riesgo humano puede ser intencional o no intencional.

[FUENTE: ISO 31000:2018, 3.4; modificada: se agregaron las Notas 1 y 2 a la entrada].

3.1.7 criterios de riesgo (*risk criteria*). Términos de referencia respecto a los cuales se evalúa la importancia del riesgo (véase el numeral 3.1.3).

Nota 1 a la entrada: los criterios de riesgo se basan en los objetivos de la organización, así como en el contexto externo (véase el numeral 3.1.1) y el contexto interno (véase el numeral 3.1.2).

Nota 2 a la entrada: los criterios de riesgo pueden derivarse de normas, leyes, políticas y otros requisitos.

[FUENTE: Guía ISO 73:2009, 3.3.1.3]

3.1.8 apetito de riesgo (*risk appetite*). Cantidad y tipo de riesgo (3.1.3) que una organización está dispuesta a buscar o retener.

[FUENTE: Guía ISO 73:2009, 3.7.1.2]

3.1.9 amenaza (*threat*). Causa potencial de un incidente de seguridad de la información (véase el numeral 3.1.12) que puede causar daños a un sistema o perjudicar a una organización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

3.1.10 vulnerabilidad (*vulnerability*). Debilidad de un activo o control (véase el numeral 3.1.16) que puede aprovecharse para que ocurra un evento (véase el numeral 3.1.11) con consecuencias (véase el numeral 3.1.14) negativas.

3.1.11 evento (*event*). Ocurrencia o cambio de un conjunto particular de circunstancias.

Nota 1 a la entrada: un evento puede tener una o más ocurrencias, y puede tener varias causas y varias consecuencias (véase el numeral 3.1.14).

Nota 2 a la entrada: un evento también puede ser algo que se espera, pero no ocurre, o algo que no se espera pero ocurre.

[FUENTE: ISO 31000:2018, 3.5; modificada: se eliminó la Nota 3 a la entrada].

3.1.12 incidente de seguridad de la información (*information security incident*). Un único evento de seguridad de la información o una serie de ellos, no deseados o inesperados, que tienen una probabilidad matemática significativa de comprometer las operaciones de la empresa y de amenazar la seguridad de la información.

3.1.13 probabilidad (*likelihood*). Potencial de que algo ocurra.

Nota 1 a la entrada: en la terminología de la gestión de riesgos, la palabra “probabilidad” se utiliza para referirse al potencial de que algo ocurra, ya sea definido, medido o determinado objetiva o subjetivamente, cualitativa o cuantitativamente, y se describe utilizando términos generales o matemáticos (como una probabilidad matemática o una frecuencia para un periodo de tiempo determinado).

Nota 2 a la entrada: el término inglés “likelihood” no tiene un equivalente directo en algunos idiomas; en su lugar, se utiliza con frecuencia el término “probability”. Sin embargo, en inglés, “probability” se interpreta frecuentemente de manera más limitada como un término matemático. Por ello, en la terminología de la gestión del riesgo, “likelihood” se utiliza con la interpretación amplia que tiene la palabra probabilidad en otros idiomas distintos del inglés.

[FUENTE: ISO 31000:2018, 3.7]

3.1.14 consecuencia (*consequence*). Resultado de un evento (3.1.11) que afecta a los objetivos.

Nota 1 a la entrada: una consecuencia puede ser determinada o indeterminada, y puede tener efectos positivos o negativos, directos o indirectos, sobre los objetivos.

Nota 2 a la entrada: las consecuencias pueden expresarse de manera cualitativa o cuantitativa.

Nota 3 a la entrada: cualquier consecuencia puede a través de efectos en cascada y acumulativos.

[FUENTE: ISO 31000:2018, 3.6]

3.1.15 nivel de riesgo (*level of risk*). Importancia de un riesgo (véase el numeral 3.1.3), expresada en términos de la combinación de las consecuencias (véase el numeral 3.1.14) y su probabilidad (véase el numeral 3.1.13)

[FUENTE: Guía ISO 73:2009, 3.6.1.8; modificada: la frase: “magnitud de un riesgo o combinación de riesgos” se sustituyó por “importancia de un riesgo”].

3.1.16 control (*control*). Medida que mantiene o modifica el riesgo (véase el numeral 3.1.3)

Nota 1 a la entrada: los controles comprenden, entre otros, cualquier proceso, política, dispositivo, práctica u otras condiciones o acciones que mantengan o modifiquen el riesgo.

Nota 2 a la entrada: es posible que los controles no siempre ejerzan el efecto modificador previsto o supuesto.

[FUENTE: ISO 31000:2018, 3.8]

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

3.1.17 riesgo residual (*residual risk*). Riesgo (véase el numeral 3.1.3) que queda tras el tratamiento del riesgo (véase el numeral 3.2.7).

Nota 1 a la entrada: el riesgo residual puede contener riesgos no identificado.

Nota 2 a la entrada: el riesgo residual también puede contener riesgos retenidos.

[FUENTE: Guía ISO 73:2009, 3.8.1.6; modificada: se modificó la Nota 2 a la entrada].

3.2 Términos relacionados con la gestión de riesgos para la seguridad de la información

3.2.1 proceso de gestión del riesgo (*risk management process*). Aplicación sistemática de políticas, procedimientos y prácticas de gestión a las actividades de comunicación, consulta y establecimiento del contexto, y la identificación, análisis, evaluación, tratamiento, monitoreo y revisión del riesgo (véase el numeral 3.1.3)

[FUENTE: Guía ISO 73:2009, 3.1]

3.2.2 comunicación de riesgos y consulta (*risk communication and consultation*). Serie de procesos continuos e iterativos que una organización lleva a cabo para proporcionar, compartir u obtener información, así como para entablar un diálogo con las partes interesadas en relación con la gestión del riesgo (véase el numeral 3.1.3)

Nota 1 a la entrada: la información se puede estar relacionada con la existencia, naturaleza, forma, probabilidad (véase el numeral 3.1.13), importancia, valoración, aceptación y tratamiento del riesgo.

Nota 2 a la entrada: la consulta es un proceso bidireccional de comunicación informada entre una organización y sus partes interesadas sobre un asunto determinado antes de tomar una decisión o determinar una dirección al respecto. La consulta es:

- Un proceso que influye en una decisión a través de la influencia, y no del poder.
- Un insumo para la toma de decisiones, no una toma de decisiones conjunta.

3.2.3 evaluación de riesgos (*risk assessment*). Proceso global de identificación de riesgos (véase el numeral 3.2.4), análisis del riesgo (véase el numeral 3.2.5) y valoración del riesgo (véase el numeral 3.2.6).

[FUENTE: Guía ISO 73:2009, 3.4.1]

3.2.4 identificación del riesgo (*risk identification*). Proceso de encontrar, reconocer y describir el riesgo (véase el numeral 3.1.3)

Nota 1 a la entrada: la identificación de riesgos implica la identificación de las fuentes de riesgo (véase el numeral 3.1.6), los eventos (véase el numeral 3.1.11), sus causas y consecuencias (véase el numeral 3.1.14) potenciales.

Nota 2 a la entrada: la identificación del riesgo puede incluir datos históricos, análisis teóricos, opiniones informadas y de expertos, y necesidades de las partes interesadas.

[FUENTE: Guía ISO 73:2009, 3.5.1; modificada: “parte interesada” (*interested party*) ha sustituido a “parte interesada” (*stakeholder*) en la Nota 2 a la entrada].

3.2.5 análisis del riesgo (*risk analysis*). Proceso para comprender la naturaleza del riesgo (véase el numeral 3.1.3) y determinar el nivel de riesgo (véase el numeral 3.1.15).

Nota 1 a la entrada: el análisis del riesgo proporciona la base para la valoración del riesgo (3.2.6) y las decisiones sobre su tratamiento (véase el numeral 3.2.7).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Nota 2 a la entrada: el análisis del riesgo incluye la estimación del riesgo.

[FUENTE: Guía ISO 73:2009, 3.6.1]

3.2.6 valoración del riesgo (*risk evaluation*). Proceso de comparar los resultados del análisis del riesgo (véase el numeral 3.2.5) con los criterios de riesgo (véase el numeral 3.1.7) para determinar si el riesgo (véase el numeral 3.1.3) o su importancia son aceptables o tolerables.

Nota 1 a la entrada: la valoración del riesgo ayuda en la decisión sobre el tratamiento del riesgo (véase el numeral 3.2.7).

[FUENTE: Guía ISO 73:2009, 3.7.1, modificada - "importancia" ha sustituido a "magnitud"].

3.2.7 tratamiento del riesgo (*risk treatment*). Proceso para modificar el riesgo (véase el numeral 3.1.3).

Nota 1 a la entrada: el tratamiento del riesgo puede implicar:

- Evitar el riesgo, decidiendo no iniciar o continuar la actividad que lo origina.
- Asumir o aumentar el riesgo para perseguir una oportunidad.
- Eliminar la fuente de riesgo (véase el numeral 3.1.6).
- Cambiar la probabilidad (véase el numeral 3.1.13).
- Cambiar las consecuencias (véase el numeral 3.1.14).
- Compartir el riesgo con otra u otras partes (incluidos los contratos y la financiación del riesgo).
- Retener el riesgo, mediante una decisión informada.

Nota 2 a la entrada: el tratamiento del riesgo de seguridad de la información no incluye "asumir o aumentar el riesgo para perseguir una oportunidad", pero la organización puede tener esta opción para la gestión general del riesgo.

Nota 3 a la entrada: los tratamientos del riesgo que tratan con las consecuencias negativas a veces se denominan "mitigación del riesgo", "eliminación del riesgo", "prevención del riesgo" y "reducción del riesgo".

Nota 4 a la entrada: el tratamiento del riesgo puede crear nuevos riesgos o modificar los existentes.

[FUENTE: Guía ISO 73:2009, 3.8.1; modificada: se agregó la Nota 1 a la entrada, y las Notas 1 y 2 a la entrada originales se enumeraron como Nota 2 y 3 a la entrada].

3.2.8 aceptación del riesgo (*risk acceptace*). Decisión informada de asumir un determinado riesgo (véase el numeral 3.1.3).

Nota 1 a la entrada: la aceptación del riesgo puede producirse sin tratamiento del riesgo (véase el numeral 3.2.7) o durante el proceso de tratamiento del riesgo.

Nota 2 a la entrada: los riesgos aceptados están sujetos a monitoreo y revisión.

[FUENTE: Guía ISO 73:2009, 3.7.1.6]

3.2.9 compartir el riesgo (*risk sharing*). Forma de tratamiento del riesgo (véase el numeral 3.2.7) que implica la distribución acordada del riesgo (véase el numeral 3.1.3) con otras partes.

Nota 1 a la entrada: los requisitos legales o reglamentarios pueden limitar, prohibir u obligar a compartir el riesgo.

Nota 2 a la entrada: compartir el riesgo puede llevarse a cabo través de seguros u otras formas de contrato.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Nota 3 a la entrada: el grado en que se comparte del riesgo puede depender de la confiabilidad y claridad de los acuerdos para compartirlo.

Nota 4 a la entrada: la transferencia del riesgo es una forma de compartir el riesgo.

[FUENTE: Guía ISO 73:2009, 3.8.1.3]

3.2.10 retención del riesgo (*risk retention*). Aceptación temporal del beneficio potencial de ganancia, o de la carga de pérdida, de un riesgo (véase el numeral 3.1.3) en particular.

Nota 1 a la entrada: la retención puede limitarse a un determinado periodo de tiempo.

Nota 2 a la entrada: el nivel de riesgo (véase el numeral 3.1.15) retenido puede depender de criterios de riesgo (véase el numeral 3.1.7).

[FUENTE: Guía ISO 73:2009, 3.8.1.5; modificada: se agregó la palabra “temporal” a la definición, y la frase “la retención de riesgos incluye la aceptación de riesgos residuales” se sustituyó por “la retención puede limitarse a un determinado periodo de tiempo “ en la Nota 1 a la entrada].

4 ESTRUCTURA DEL DOCUMENTO

Este documento está estructurado de la siguiente manera:

- Numeral 5: Gestión de riesgos para la seguridad de la información.
- Numeral 6: Establecimiento del contexto.
- Numeral 7: Proceso de evaluación de riesgos para la seguridad de la información.
- Numeral 8: Proceso de tratamiento del riesgo para la seguridad de la información.
- Numeral 9: Operación.
- Numeral 10: Aprovechamiento de los procesos relacionados con el SGSI.

Excepto por las descripciones dadas en las subnumerales generales, todas las actividades de gestión de riesgos presentadas desde el numeral 7 hasta el numeral 10 se estructuran de la siguiente manera:

Insumo: identifica cualquier información necesaria para realizar la actividad.

Acción: describe la actividad.

Desencadenante: proporciona orientación sobre cuándo iniciar la actividad, por ejemplo, debido a un cambio dentro de la organización, o de acuerdo con un plan o un cambio en el contexto externo de la organización.

Resultado: identifica cualquier información derivada después de realizar la actividad, así como cualquier criterio que tal resultado debería satisfacer.

Orientación para la implementación: proporciona orientación sobre la realización de la actividad, palabras clave y conceptos clave.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

5 GESTIÓN DE RIESGOS PARA LA SEGURIDAD DE LA INFORMACIÓN

5.1 Proceso de gestión de riesgos para la seguridad de la información

El proceso de gestión de riesgos para la seguridad de la información se presenta en la Figura 1.

NOTA Este proceso se basa en el proceso general de gestión de riesgos definido en la NTC-ISO 31000.

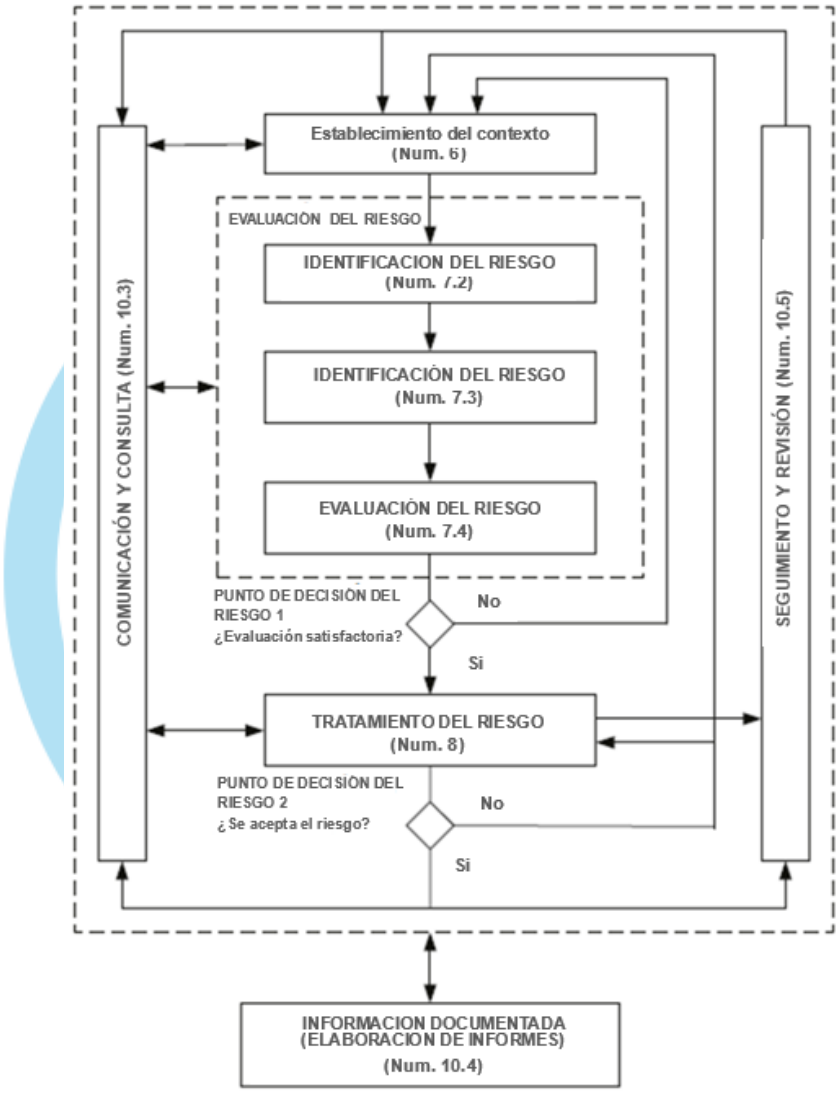


Figura 1.Proceso de gestión de riesgos para la seguridad de la información

Como lo ilustra la Figura 1, el proceso de gestión de riesgos para la seguridad de la información puede ser iterativo para las actividades de evaluación y/o de tratamiento del riesgo. Un enfoque iterativo al realizar la evaluación de riesgos puede aumentar la profundidad y el detalle de la evaluación en cada iteración. El enfoque iterativo proporciona un buen equilibrio entre minimizar el tiempo y el esfuerzo dedicado a la identificación de controles, a la vez que se garantiza que los riesgos se evalúan adecuadamente.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Establecer el contexto significa determinar el contexto interno y externo para la gestión de riesgos para la seguridad de la información o para una evaluación de riesgos para la seguridad de la información.

Si la evaluación de riesgos proporciona información suficiente para determinar eficazmente las acciones requeridas para modificar los riesgos hasta un nivel aceptable, la tarea se habrá completado y se procede al tratamiento del riesgo. Si la información es insuficiente, se debería realizar otra iteración de la evaluación de riesgos. Esto puede implicar un cambio de contexto en la evaluación del riesgo (por ejemplo, revisión del ámbito de aplicación), la participación de expertos en el campo pertinente u otras formas de recopilar la información necesaria, para permitir la modificación del riesgo hasta un nivel aceptable (véase el “Punto de decisión del riesgo 1” en la Figura 1).

El tratamiento del riesgo implica un proceso iterativo de:

- Formular y seleccionar opciones de tratamiento del riesgo.
- Planificar e implementar el tratamiento del riesgo.
- Evaluar la eficacia de dicho tratamiento.
- Decidir si el riesgo restante es aceptable.
- Realizar tratamiento adicional en caso de que no sean aceptables.

Es posible que el tratamiento del riesgo no conduzca inmediatamente a un nivel aceptable de riesgos residuales. En este caso, se puede realizar otro intento de encontrar un tratamiento del riesgo adicional, o puede haber otra iteración de la evaluación del riesgo, ya sea en su totalidad o por partes. Esto puede implicar un cambio de contexto en la evaluación de riesgos (por ejemplo, mediante una revisión del ámbito de aplicación) y la participación de expertos en el campo pertinente. El conocimiento sobre las amenazas o vulnerabilidades pertinentes puede llevar a tomar mejores decisiones sobre las actividades de tratamiento del riesgo apropiadas en la siguiente iteración de la evaluación del riesgo (véase el “Punto de decisión del riesgo 2” en la Figura 1).

El establecimiento del contexto se trata en detalle en el numeral 6; las actividades de evaluación de riesgos, en el numeral 7, y las actividades de tratamiento del riesgo, en el numeral 8.

Otras actividades necesarias para gestionar los riesgos para la seguridad de la información se tratan en el numeral 10.

5.2 Ciclos de gestión de los riesgos para la seguridad de la información

La evaluación de riesgos y el tratamiento del riesgo se deberían actualizar periódicamente y en función de los cambios. Esto debería aplicarse a toda la evaluación de riesgos, y las actualizaciones pueden dividirse en dos ciclos de gestión de riesgos:

- Ciclo estratégico, en el que los activos de la empresa, las fuentes de riesgo y las amenazas, los objetivos previstos o las consecuencias para la seguridad de la información evolucionan a partir de cambios en el contexto general de la organización. Esto puede resultar como insumos para una actualización general de la o las evaluaciones de riesgos y de los tratamientos del riesgo. También puede servir como insumo para identificar nuevos riesgos e iniciar evaluaciones de riesgos completamente nuevas.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Ciclo operativo, en el que los elementos antes mencionados sirven como insumos de información o criterios modificados que afectarán a una evaluación de riesgos o a una evaluación en las que los escenarios deberían revisarse y actualizarse. La revisión debería incluir la actualización del tratamiento del riesgo correspondiente, según proceda.

El ciclo estratégico debería llevarse a cabo a más largo plazo o cuando se produzcan cambios importantes, mientras que el ciclo operativo debería ser más corto, en función de los riesgos detallados que se identifiquen y evalúen, así como del tratamiento del riesgo relacionado.

El ciclo estratégico se aplica al entorno en el que la organización pretende alcanzar sus objetivos, mientras que el ciclo operativo se aplica a todas las evaluaciones de riesgos, tomando en consideración el contexto del proceso de gestión de riesgos. En ambos ciclos puede haber muchas evaluaciones de riesgos, con diferentes contextos y alcances en cada evaluación.

6 ESTABLECIMIENTO DEL CONTEXTO

6.1 Consideraciones organizativas

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 4.1.

Una organización se define como una persona o grupo de personas que tiene sus propias funciones, con responsabilidades, autoridades y relaciones para lograr sus objetivos. Una organización no es necesariamente una empresa, otro órgano corporativo o una entidad jurídica; también puede ser un subconjunto de una entidad jurídica (por ejemplo, el departamento de tecnologías de la información de una empresa), y puede ser considerada como la “organización” en el contexto de los SGSI.

Es importante entender que el apetito de riesgo, definido como la cantidad de riesgo que una organización está dispuesta a buscar o aceptar, puede variar considerablemente de una organización a otra. Por ejemplo, los factores que afectan a la propensión al riesgo de una organización comprenden su tamaño, su complejidad y su sector. El apetito de riesgo debería ser fijado y revisado periódicamente por la alta dirección.

La organización debería asegurarse de que el rol del propietario del riesgo se determina en función de las actividades de gestión con respecto a los riesgos identificados. Los propietarios del riesgo deberían tener la responsabilidad sobre rendición de cuentas y la autoridad adecuadas para gestionar los riesgos identificados.

6.2 Identificación de los requisitos básicos de las partes interesadas

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 4.2.

Se deberían identificar los requisitos básicos de las partes interesadas pertinentes, así como el nivel de conformidad con dichos requisitos. Esto incluye identificar todos los documentos de referencia que definan las reglas y controles de seguridad y que se apliquen en el ámbito de la evaluación de riesgos para la seguridad de la información.

Estos documentos de referencia pueden incluir, entre otras, las siguientes:

a) La NTC-ISO/IEC 27001:2022, Anexo A.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) Normas adicionales que traten sobre el SGSI.

c) Normas adicionales aplicables a un sector específico (por ejemplo, financiero, de salud).

d) Normativas internacionales o nacionales específicas.

e) Las normas internas de seguridad de la organización.

f) Normas y controles de seguridad provenientes de contratos o acuerdos.

g) Controles de seguridad implementados, basados en actividades previas de tratamiento del riesgo.

Todo incumplimiento de los requisitos básicos debería explicarse y justificarse. Estos requisitos básicos y su cumplimiento deberían ser un insumo para la evaluación de probabilidad y para el tratamiento del riesgo.

6.3 Aplicación de la evaluación del riesgo

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 4.3.

Las organizaciones pueden realizar evaluaciones de riesgos integradas en muchos procesos diferentes, como en la gestión de proyectos, la gestión de vulnerabilidades, la gestión de incidentes, la gestión de problemas, o incluso de forma imprevista para un tema específico determinado. Independientemente de cómo se realicen las evaluaciones de riesgos, deberían cubrir colectivamente todos los temas relevantes para la organización dentro del alcance de un SGSI.

La evaluación de riesgos debería ayudar a la organización a tomar decisiones sobre la gestión de los riesgos que afectan al logro de sus objetivos. Por lo tanto, debería dirigirse a aquellos riesgos y controles que, si se gestionan con éxito, mejorarán la probabilidad de que la organización alcance sus objetivos.

En la GTC-ISO/IEC 27003 se ofrece más información sobre el contexto de un SGSI y las cuestiones por comprender a través de la evaluación de riesgos.

6.4 Establecer y mantener criterios de riesgo para la seguridad de la información

6.4.1 Generalidades

El numeral 6.1.2, entrada a), de la NTC-ISO/IEC 27001:2022, especifica los requisitos para que las organizaciones definan sus criterios de riesgo, es decir, los términos de referencia mediante los cuales valoran la importancia de los riesgos que identifican y toman decisiones con respecto a los riesgos.

La NTC-ISO/IEC 27001 especifica los requisitos para que una organización establezca y mantenga criterios de riesgo para la seguridad de la información que incluyan:

a) Los criterios de aceptación de riesgos.

b) Los criterios para realizar evaluaciones de riesgos para la seguridad de la información.

En general, para establecer los criterios de riesgo, se debería considerar lo siguiente:

- La naturaleza y el tipo de incertidumbres que pueden afectar los resultados y los objetivos (tangibles e intangibles).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Cómo se definirán, predecirán y medirán las consecuencias y la probabilidad.
- Factores temporales.
- Consistencia en el uso de las mediciones.
- Cómo se determinará el nivel de riesgo.
- Cómo se tendrán en cuenta las combinaciones y secuencias de riesgos múltiples.
- La capacidad de la organización.

En el Anexo A (Informativo) se presentan consideraciones adicionales sobre los criterios de riesgo.

6.4.2 Criterios de aceptación del riesgo

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem a) 1).

En la valoración del riesgo, se deberían utilizar los criterios de aceptación del riesgo para determinar si un riesgo es aceptable o no.

En el tratamiento del riesgo, los criterios de aceptación del riesgo se pueden utilizar para determinar si el tratamiento del riesgo propuesto es suficiente para alcanzar un nivel de riesgo aceptable o si es necesario un tratamiento del riesgo adicional.

Una organización debería definir los niveles de aceptación del riesgo. Durante el desarrollo se debería considerar lo siguiente:

a) La consistencia entre los criterios de aceptación de riesgos para la seguridad de la información y los criterios generales de aceptación de riesgos de la organización.

b) La identificación del nivel de dirección con autoridad delegada para tomar decisiones de aceptación de riesgos.

c) Los criterios de aceptación de riesgos pueden incluir múltiples umbrales, y la autoridad para la aceptación puede asignarse a diferentes niveles de gestión.

d) Los criterios de aceptación de riesgos pueden basarse únicamente en la probabilidad y las consecuencias, o ampliarse para considerar también el equilibrio costo/beneficio entre las pérdidas previstas y el costo de los controles.

e) Se pueden aplicar diferentes criterios de aceptación de riesgos a diferentes clases de riesgos (por ejemplo, no siempre se retienen los riesgos que pueden dar lugar al incumplimiento de reglamentos o leyes, mientras que se puede permitir la aceptación de riesgos si la aceptación es resultado de un requisito contractual).

f) Los criterios de aceptación del riesgo pueden incluir requisitos para un futuro tratamiento adicional (por ejemplo, un riesgo puede retenerse a corto plazo, incluso si el nivel de riesgo supera los criterios de aceptación del riesgo, si existe la aprobación y el compromiso de tomar medidas para aplicar una serie determinada de controles para alcanzar un nivel aceptable en un periodo de tiempo definido).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

g) Los criterios de aceptación del riesgo deberían definirse con base en el apetito de riesgo, que indica la cantidad y el tipo de riesgo que la organización está dispuesta a perseguir o retener.

h) Los criterios de aceptación del riesgo pueden ser absolutos o condicionales, de acuerdo con el contexto.

Los criterios de aceptación del riesgo se deberían establecer considerando los siguientes factores de influencia:

- Objetivos de la organización.
- Oportunidades organizativas.
- Aspectos legales y reglamentarios.
- Actividades operativas.
- Limitaciones tecnológicas.
- Limitaciones financieras.
- Procesos.
- Relaciones con los proveedores.
- Factores humanos (por ejemplo, relacionados con la privacidad).

La lista de factores de influencia no es absoluta. La organización debería considerar los factores de influencia de acuerdo con el contexto.

En la práctica, no siempre es suficiente un simple criterio de aceptación (sí/no).

En muchos casos, la decisión de aceptar el riesgo puede tomarse en niveles específicos de riesgo (combinaciones específicas de probabilidad y consecuencia). Sin embargo, puede haber circunstancias en las que sea necesario establecer umbrales de aceptación para consecuencias extremas, independientemente de su probabilidad, o para probabilidades extremadamente altas, independientemente de las consecuencias, cuando el efecto sobre la organización provenga principalmente de una u otra.

Por ejemplo, la aceptación de un evento poco frecuente que aniquile el valor bursátil de una empresa, o de una fuga constante de recursos, que resulte de la necesidad de controlar infracciones menores y frecuentes de una política debería considerarse, principalmente, en función de cuál de los dos factores tenga el efecto dominante sobre la organización.

En consecuencia, los criterios de aceptación del riesgo deberían, idealmente, incluir la consideración de la probabilidad y la consecuencia de forma independiente, así como los costos de gestión, en lugar de limitarse a considerar el nivel de riesgo como combinación de probabilidad y consecuencia.

Una organización con un apetito de riesgo agudo puede establecer un umbral de aceptación más alto, y aceptar así más riesgos que una organización con un apetito de riesgo más bajo. Esto protege a la organización de un exceso de control, es decir, de tener tantos controles de seguridad de la información que impidan la capacidad de la organización para alcanzar sus objetivos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Los criterios de aceptación del riesgo pueden diferir de acuerdo con el tiempo que se prevé que van a existir los riesgos (por ejemplo, los riesgos pueden estar asociados a una actividad temporal o de corto plazo).

Los criterios de riesgo deberían ser revisados y actualizados según sea necesario, como resultado de cualquier cambio en el contexto de la gestión de riesgos para la seguridad de la información.

EJEMPLO Una pequeña empresa puede comenzar con un gran apetito de riesgo, pero, a medida que crece, puede disminuirla.

Los criterios de aceptación del riesgo deberían ser aprobados por el nivel de dirección autorizado.

6.4.3 Criterios para realizar evaluaciones de riesgos para la seguridad de la información

6.4.3.1 Generalidades

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, entrada a) 2).

Los criterios de evaluación de riesgos especifican la forma en que se determina la importancia de un riesgo, en términos de sus consecuencias, probabilidad y nivel de riesgo.

Los criterios de evaluación de riesgos para la seguridad de la información deberían tomar en cuenta la idoneidad de las actividades de gestión de riesgos.

Las consideraciones para lograrlo incluyen:

a) El nivel de clasificación de la información.

b) La cantidad y, en su caso, la concentración de la información.

c) El valor estratégico de los procesos empresariales que hacen uso de la información.

d) La criticidad de la información y de los activos relacionados con la información de que se trate.

e) La importancia operativa y empresarial de la disponibilidad, la confidencialidad y la integridad.

f) Las expectativas y percepciones de las partes interesadas (por ejemplo, de la alta dirección).

g) Las consecuencias negativas, como la pérdida de fondo de comercio y de reputación.

h) La consistencia con los criterios de riesgo de la organización.

Los criterios de evaluación de riesgos, o una base formal para definirlos, deberían normalizarse en toda la organización para todos los tipos de evaluación de riesgos, ya que esto puede facilitar la comunicación, comparación y agregación de riesgos asociados con múltiples áreas empresariales.

Los criterios de evaluación de riesgos para la seguridad de la información suelen incluir:

- Consecuencias.
- Probabilidad.
- Nivel de riesgo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

6.4.3.2 Criterios de consecuencia

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem a) 2).

La NTC-ISO/IEC 27001 se refiere a las consecuencias que se ven afectadas, directa o indirectamente, por la preservación o pérdida de la confidencialidad, la integridad y la disponibilidad de la información en el ámbito del SGSI. Los criterios de consecuencia deberían desarrollarse y especificarse en términos del alcance del daño o la pérdida, o del perjuicio para una organización o individuo, resultantes de la pérdida de confidencialidad, integridad y disponibilidad de la información. Al definir los criterios de consecuencia, se debería tener en especial consideración lo siguiente:

a) Pérdida de vidas o daños a personas o grupos.

b) Pérdida de libertad, dignidad o derecho a la privacidad.

c) Pérdida de personal y de capital intelectual (competencias y conocimientos especializados).

d) Menoscabo de las operaciones internas o de terceros (por ejemplo, daños a una función o proceso empresarial).

e) Afectación de planes y plazos.

f) Pérdida de valor empresarial y financiero.

g) Pérdida de ventajas comerciales o de cuotas de mercado.

h) Daños a la confianza o reputación públicas.

i) Incumplimientos de requisitos legales, reglamentarios o estatutarios.

j) Incumplimiento de contratos o niveles de servicio.

k) Impacto negativo en las partes interesadas.

l) Impacto negativo en el medio ambiente, contaminación.

Los criterios de consecuencia definen cómo una organización categoriza la importancia de los posibles eventos de seguridad de la información para la organización. Es fundamental determinar cuántas categorías de consecuencias se utilizan, cómo se definen y qué consecuencias se asocian a cada categoría. Generalmente, los criterios de consecuencia son diferentes para diferentes organizaciones, según el contexto interno y externo de la organización.

EJEMPLO 1 La cantidad máxima que la organización está dispuesta a amortizar en un año fiscal y la cantidad mínima, para el mismo periodo, que la obligaría a liquidar pueden crear límites superiores e inferiores realistas de la escala de consecuencias de una organización, expresados en términos monetarios.

Esta escala, dependiente del contexto, puede luego dividirse en varias categorías de consecuencias, cuyo número y distribución deberían depender de la percepción de riesgo y el apetito de riesgo de la organización. Las escalas de consecuencias monetarias generalmente se expresan en una escala logarítmica, como en décadas o en potencias de 10 (por ejemplo, de 100 a 1 000. De 1 a 10 000, entre otras), pero pueden utilizarse esquemas de cuantificación alternativos cuando se ajusten mejor al contexto de la organización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Dado que las consecuencias en distintos ámbitos o departamentos de una organización pueden expresarse inicialmente de diversas formas, en lugar de estrictamente en términos monetarios, resulta útil que estas diversas expresiones puedan cruzarse mediante una escala de anclaje común, para garantizar que niveles aproximadamente equivalentes de consecuencia, en los distintos ámbitos, se comparen correctamente entre sí. Esto debería permitir realizar una agregación de riesgos entre dominios.

EJEMPLO 2 Una violación de datos, además de afectar posiblemente a la privacidad individual, puede provocar la pérdida de confidencialidad, integridad o disponibilidad de la información en el ámbito del SGSI. Así mismo, puede provocar el incumplimiento de la legislación aplicable en materia de protección de datos. Las consecuencias potenciales van desde la pérdida de información, la pérdida de activos relacionados con la información y el proceso de información, hasta la pérdida de objetivos empresariales operativos y del negocio proyectado.

6.4.3.3 Criterios de probabilidad

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem a) 2).

La determinación de los criterios de probabilidad depende de aspectos tales como:

a) Eventos naturales o accidentales.

b) El grado de exposición a la amenaza que tiene la información pertinente o el activo relacionado con la información.

c) El grado de explotación de la vulnerabilidad de la organización.

d) Fallas tecnológicas.

e) Actos humanos u omisiones.

La probabilidad puede expresarse en términos probabilísticos (la posibilidad de que se produzca un evento en un plazo determinado) o en términos frecuentistas (el número medio teórico de ocurrencias durante un plazo determinado). La probabilidad frecuentista se suele utilizar cuando se comunica, aunque solo se puede utilizar la probabilidad expresada en términos probabilísticos para realizar la agregación de probabilidades.

Los criterios de probabilidad deberían abarcar la gama de probabilidades de eventos pronosticados que pueda gestionarse de forma previsible. Más allá de los límites de la capacidad viable para gestionarlos, normalmente solo es necesario reconocer que se ha superado uno u otro límite para tomar una decisión adecuada de gestión del riesgo (designación como caso extremo). Si las escalas son muy amplias, el resultado comúnmente será una cuantificación excesivamente amplia, que puede conducir a errores de la evaluación. Esto ocurre especialmente cuando las probabilidades se sitúan en el extremo superior de escalas representadas exponencialmente, ya que los incrementos en los rangos superiores son intrínsecamente muy amplios.

Aunque casi todo es “posible”, las fuentes de riesgo a las que se debería prestar atención prioritaria son aquellas con probabilidades más relevantes para el contexto de la organización y el alcance de su SGSI.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

6.4.3.4 Criterios para determinar el nivel de riesgo

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem a) 2).

El propósito de las escalas para el nivel de riesgo es ayudar a los propietarios del riesgo a decidir acerca de retener o, por el contrario, tratar los riesgos, y a priorizarlos para su tratamiento. El nivel evaluado de un riesgo determinado debería ayudar a la organización a establecer la urgencia de tratar ese riesgo.

Dependiendo de la situación, se recomienda considerar el nivel de riesgo inherente (sin tomar en consideración ningún control) o el nivel de riesgo actual (tomando la eficacia de cualquier control ya implementado). La organización debería elaborar una clasificación de los riesgos teniendo en cuenta lo siguiente:

a) Los criterios de consecuencia y de probabilidad.

b) Las consecuencias que pueden tener los eventos de seguridad de la información a nivel estratégico, táctico y operativo (esto puede definirse como el peor de los casos o en otros términos, siempre que se utilice la misma base de forma consistente).

c) Requisitos legales y reglamentarios, y obligaciones contractuales.

d) Los riesgos que aparecen más allá de los límites del ámbito de la organización, incluidos los efectos imprevistos sobre terceros.

Los criterios para el nivel de riesgo son necesarios para valorar los riesgos analizados.

Los criterios para el nivel de riesgo pueden ser cualitativos (por ejemplo, muy alto, alto, medio, bajo) o cuantitativos (por ejemplo, expresados en términos del valor esperado de pérdida monetaria, en pérdida de vidas o en cuotas de mercado en un periodo de tiempo determinado).

EJEMPLO Los riesgos pueden cuantificarse como expectativa de pérdida anual, es decir, el valor monetario medio de la consecuencia por año, tomado durante el año siguiente.

Independientemente de que se utilicen criterios cuantitativos o cualitativos, en última instancia, las escalas de valoración deberían anclarse a una escala de referencia que todas las partes interesadas comprendan, y tanto el análisis como la valoración del riesgo deberían incluir al menos una calibración formal periódica con respecto a la escala de referencia, para garantizar la validez, consistencia y comparabilidad de los resultados.

Si se utiliza un enfoque cualitativo, los niveles de cualquier escala cualitativa deberían ser inequívocos, sus incrementos deberían estar claramente definidos, las descripciones cualitativas de cada nivel deberían expresarse en un lenguaje objetivo, y los niveles no deberían traslaparse. Cuando se utilicen diferentes escalas (por ejemplo, para abordar riesgos en diferentes ámbitos empresariales), debería existir una equivalencia que permita obtener resultados comparables.

6.5 Elección de un método adecuado

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem b).

En general, el enfoque y los métodos de gestión de los riesgos para la seguridad de la información deberían estar alineados con el enfoque y los métodos utilizados para gestionar los demás riesgos de la organización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

El enfoque elegido debería documentarse.

Según lo establecido en la NTC-ISO/IEC 27001:2022, numeral 6.1.2, entrada b), se requiere que la organización, en el objeto y campo de aplicación del SGSI, garantice que las repetidas evaluaciones de riesgos para la seguridad de la información produzcan resultados consistentes, válidos y comparables. Esto significa que el método elegido debería garantizar las siguientes propiedades de los resultados:

- Consistencia: las evaluaciones de los mismos riesgos, realizadas por diferentes personas o por las mismas personas en diferentes ocasiones, en el mismo contexto, deberían producir resultados similares.

- Comparabilidad: se deberían definir criterios de evaluación de los riesgos para garantizar que las evaluaciones realizadas para riesgos diferentes produzcan resultados comparables si representan niveles de riesgo equivalentes.

- Validez: las evaluaciones deberían producir resultados que se ajusten lo más posible a la realidad.

Los métodos de gestión de riesgos operativos generalmente se utilizan para la gestión de riesgos para la seguridad de la información. El método elegido puede utilizar cualquier enfoque apropiado con respecto al uso del riesgo residual. Los enfoques más utilizados para la gestión de riesgos de seguridad de la información utilizan el riesgo actual al evaluar la probabilidad y la consecuencia de los riesgos.

7 PROCESO DE EVALUACIÓN DE RIESGOS PARA LA SEGURIDAD DE LA INFORMACIÓN

7.1 Generalidades

La organización debería utilizar el proceso de evaluación de riesgos de la organización (si está establecido) para evaluar los riesgos para la información o para definir un proceso de evaluación de riesgos para la seguridad de la información.

La evaluación de riesgos les permite a los propietarios del riesgo priorizar los riesgos, alineándose con la perspectiva de tratamiento, basándose principalmente en sus consecuencias y probabilidad o en otros criterios establecidos.

Se debería determinar el contexto de la evaluación de riesgos, incluida una descripción del alcance y el propósito, así como las cuestiones internas y externas que afectan a la evaluación de riesgos.

La evaluación de riesgos consiste en las siguientes actividades:

a) Identificación del riesgo, que es un proceso para encontrar, reconocer y describir los riesgos (en el numeral 7.2 se ofrecen más detalles sobre la identificación de riesgos).

b) Análisis del riesgo, que es un proceso para comprender los tipos de riesgo y determinar el nivel de riesgo. El análisis del riesgo implica la consideración de las causas y las fuentes de riesgo, la probabilidad de que se produzca un evento específico, la probabilidad de que este evento tenga consecuencias y la gravedad de dichas consecuencias (en el numeral 7.3 se ofrecen más detalles sobre el análisis del riesgo).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) Valoración del riesgo, que es un proceso para comparar los resultados del análisis del riesgo con los criterios de riesgo para determinar si el riesgo o su importancia son aceptables y para priorizar los riesgos analizados para el tratamiento del riesgo. Basándose en esta comparación, se puede considerar la necesidad de tratamiento (en el numeral 7.4 se ofrecen más detalles sobre la valoración del riesgo).

El proceso de evaluación de riesgos debería estar basado en métodos (véase el numeral 6.5) e instrumentos diseñados con el suficiente detalle para garantizar, en la medida de lo posible, resultados consistentes, válidos y reproducibles. Además, el resultado debería ser comparable, por ejemplo, para determinar si el nivel de riesgo aumentó o disminuyó.

La organización debería asegurarse de que su enfoque de gestión de riesgos para la seguridad de la información se ajusta al enfoque de gestión de riesgos de la organización, de modo que cualquier riesgo para la seguridad de la información pueda compararse con otros riesgos de la organización, y no se considere únicamente de forma aislada.

La NTC-ISO/IEC 27001 no exige un enfoque específico para cumplir con los requisitos del numeral 6.1.2 de la NTC-ISO/IEC 27001:2022. No obstante, existen dos enfoques principales para la evaluación: un enfoque basado en eventos y un enfoque basado en activos. Estos se tratan con más detalle en el numeral 7.2.1.

7.2 Identificación de los riesgos para la seguridad de la información

7.2.1 Identificación y descripción de los riesgos para la seguridad de la información

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem c) 1).

Insumo: eventos que pueden influir negativamente en el logro de los objetivos de seguridad de la información en la organización o en otras organizaciones.

Acción: se deberían identificar los riesgos asociados a la pérdida de confidencialidad, de integridad y de disponibilidad de la información.

Desencadenante: los propietarios del riesgo, las partes interesadas o los expertos detectan o tienen la necesidad de buscar eventos o situaciones, nuevos o modificados, que pueden afectar a el logro de los objetivos de seguridad de la información.

Resultado: una lista de los riesgos identificados.

Orientación para la implementación:

La identificación de riesgos es el proceso de encontrar, reconocer y describir los riesgos. Esto implica la identificación de fuentes y eventos de riesgo.

El objetivo de la identificación de riesgos es generar una lista de riesgos basada en aquellos eventos que pueden impedir, afectar o retrasar el logro de los objetivos de seguridad de la información.

Los riesgos identificados deberían ser aquellos que, de materializarse, pueden tener un efecto sobre el logro de los objetivos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

El numeral 6.1.2, ítem c), de la NTC-ISO/IEC 27001:2022, requiere que la organización defina y aplique un proceso de evaluación de riesgos para la seguridad de la información que identifique los riesgos para la seguridad de la información. Hay dos enfoques comúnmente utilizados para realizar la identificación de riesgos.

a) Enfoque basado en eventos: identificar escenarios estratégicos a través de una consideración de las fuentes de riesgo y cómo utilizan o impactan en las partes interesadas para alcanzar el objetivo deseado de esos riesgos.

b) Enfoque basado en activos: identificar escenarios operativos, que se detallan en términos de activos, amenazas y vulnerabilidades.

En un enfoque basado en eventos, el concepto subyacente es que los riesgos pueden ser identificados y evaluados a través de una valoración de eventos y consecuencias. Los eventos y consecuencias a menudo pueden determinarse mediante un descubrimiento de las preocupaciones de la alta dirección y los propietarios del riesgo, y con los requisitos identificados al determinar el contexto de la organización (numeral NTC-ISO/IEC 27001:2022, numeral 4). Las entrevistas con la alta dirección y las personas de la organización que tienen una responsabilidad en un proceso empresarial pueden ayudar a identificar no solo los eventos y consecuencias relevantes, sino también a los propietarios del riesgo.

Un enfoque basado en eventos puede establecer escenarios de alto nivel o escenarios estratégicos sin dedicar una cantidad de tiempo considerable a la identificación de activos a un nivel detallado. Esto permite a la organización centrar sus esfuerzos de tratamiento del riesgo en los riesgos críticos. La valoración de eventos mediante este enfoque puede hacer uso de datos históricos en los que los riesgos permanezcan invariables durante largos periodos, y permite a las partes interesadas implicadas alcanzar sus objetivos. Sin embargo, en el caso de los riesgos para los que no se dispone de datos históricos o éstos no son fiables, el asesoramiento basado en el conocimiento y la experiencia de expertos o la investigación de las fuentes de riesgo pueden ayudar a la valoración.

Con un enfoque basado en activos, el concepto subyacente es que los riesgos pueden identificarse y evaluarse mediante una inspección de activos, amenazas y vulnerabilidades. Un activo es cualquier cosa que tenga valor para la organización y que, por tanto, requiera protección. Los activos deberían identificarse tomando en consideración que un sistema de información está formado por actividades, procesos e información que hay que proteger. Los activos pueden identificarse como primarios y de apoyo, según su tipo y prioridad, destacando sus dependencias, así como sus interacciones con sus fuentes de riesgo y con las partes interesadas de la organización. Una amenaza aprovecha una vulnerabilidad de un activo para comprometer la confidencialidad, la integridad o la disponibilidad de la información correspondiente. Si todas las combinaciones válidas de activos, amenazas y vulnerabilidades pueden enumerarse dentro del ámbito del SGSI, entonces, en teoría, todos los riesgos estarían identificados. Para los pasos posteriores de la evaluación de riesgos, debería elaborarse una lista de los activos asociados con la información y las instalaciones de procesamiento de la información.

El enfoque basado en los activos puede identificar amenazas y vulnerabilidades específicas de los activos y permite a la organización determinar el tratamiento específico de los riesgos a un nivel detallado.

En el Anexo A se ofrece más información sobre ambos enfoques.

En principio, los dos enfoques solamente difieren en cuanto al nivel en el que se inicia la identificación. Ambos enfoques pueden describir el mismo escenario de riesgo, por ejemplo, si un activo de información se encuentra en el nivel de detalle y una exposición a nivel empresarial se encuentra en el nivel general. La identificación de las fuentes de riesgo que contribuyen a la situación mediante una evaluación

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

basada en eventos suele requerir una búsqueda descendente desde el nivel general del escenario hasta el nivel de detalle, mientras que una evaluación basada en activos suele hacer una búsqueda ascendente desde el activo hasta el escenario, con el fin de proporcionar visibilidad sobre cómo se acumulan las consecuencias.

La identificación de riesgos es fundamental, ya que un riesgo para la seguridad de la información que no se identifique en esta fase no se incluirá en un análisis posterior.

La identificación de riesgos debería considerar los riesgos independientemente de si su fuente está bajo el control de la organización, incluso si no hay fuentes de riesgo específicas evidentes. Especialmente cuando se evalúan escenarios de riesgo complejos, se debería realizar una evaluación de riesgos iterativa. La primera ronda se debería concentrar en observaciones de alto nivel, y las rondas sucesivas deberían abordar niveles de detalle adicionales hasta que se puedan identificar las causas raíz de los riesgos.

Se puede utilizar cualquier otro enfoque de identificación de riesgos siempre que garantice la obtención de resultados consistentes, válidos y comparables, cumpliendo así el requisito del numeral 6.1.2, ítem b), de la NTC-ISO/IEC 27001:2022.

La gestión de los riesgos para la seguridad de la información no debería verse limitada por puntos de vista arbitrarios o restrictivos sobre cómo se deberían estructurar, agrupar, agregar, dividir o describir los riesgos. Puede parecer que los riesgos se traslapan o que son subconjuntos o instancias específicas de otros riesgos. Sin embargo, se deberían considerar e identificar los controles de los riesgos individuales por separado de los riesgos más amplios o de los riesgos agregados, a efectos del tratamiento del riesgo.

EJEMPLO 1 Un ejemplo de dos riesgos que se traslapan: (1) existe el riesgo de incendio en la sede central; (2) existe el riesgo de que un incendio afecte al funcionamiento del departamento de contabilidad cuando éste se encuentra en la sede central pero también en otros edificios.

Un ejemplo de casos específicos de un riesgo: (1) hay un incidente de pérdida de datos; (2) hay un incidente de pérdida de datos personales.

El segundo riesgo es una instancia específica del primer riesgo, pero es probable que tenga atributos y controles diferentes a los del primer riesgo, y puede ser importante gestionarlo por separado del primer riesgo, que es mucho más amplio.

La agregación de riesgos no debería llevarse a cabo a menos que sean pertinentes entre sí en el nivel en que se esté considerando el contexto de la organización. Puede ser necesario considerar por separado riesgos que están fusionados, a efectos de presupuestar la gestión global de riesgos cuando se planifican las opciones de tratamiento, ya que pueden ser necesarios diferentes controles para gestionarlos.

EJEMPLO 2 Un centro de datos puede estar sujeto a varios riesgos independientes: inundación, incendio, picos de tensión eléctrica y vandalismo.

Para calcular el nivel global de riesgo corporativo, los riesgos individuales de estos eventos se pueden combinar en un nivel global de riesgo, pero como cada uno de estos eventos requiere controles diferentes para gestionar el riesgo, se deberían considerar e identificar por separado a efectos del tratamiento del riesgo. Los riesgos (combinaciones de probabilidades y consecuencias) no siempre pueden agregarse directamente.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

7.2.2 Identificación de los propietarios del riesgo

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem c) 2).

Insumo: lista de riesgos identificados.

Acción: los riesgos deberían asociarse a los propietarios del riesgo.

Desencadenante: la identificación de los propietarios del riesgo se hace necesaria cuando:

- No se ha hecho antes.
- Hay un cambio de personal en el área empresarial pertinente donde residen los riesgos.

Resultado: lista de propietarios del riesgo con los riesgos asociados.

Orientaciones para la implementación:

La alta dirección, el comité de seguridad, los propietarios de los procesos, los propietarios funcionales, los directores de departamento y los propietarios de los activos pueden ser los propietarios del riesgo.

Una organización debería utilizar el proceso de evaluación de riesgos de la organización (si está establecido) en lo que respecta a la identificación de los propietarios del riesgo, o bien debería definir criterios para identificar a los propietarios del riesgo. Dichos criterios deberían tomar en consideración que los propietarios del riesgo:

- Tienen que rendir cuentas y tienen la autoridad para gestionar los riesgos que les corresponden, es decir, deberían ocupar un puesto en la organización que les permita ejercer realmente esta autoridad.
- Comprenden los problemas en cuestión y están en condiciones de tomar decisiones informadas (por ejemplo, sobre cómo tratar los riesgos).

El nivel de riesgo y a qué activo debería aplicarse el riesgo pueden servir como base para identificar a los propietarios del riesgo.

La asignación debería suceder como parte del proceso de evaluación de riesgos.

7.3 Análisis de los riesgos para la seguridad de la información

7.3.1 Generalidades

El análisis del riesgo tiene como objetivo determinar el nivel de riesgo.

La NTC-ISO 31000 se menciona en la NTC-ISO/IEC 27001 como modelo general. El numeral 6.1.2 de la NTC-ISO/IEC 27001:2022 requiere que para, cada riesgo identificado, el análisis del riesgo se base en la evaluación de las consecuencias derivadas del riesgo y en la evaluación de la probabilidad del riesgo, para determinar un nivel de riesgo.

Las técnicas para el análisis del riesgos basado en las consecuencias y la probabilidad pueden ser:

a) cualitativos, mediante una escala de atributos calificativos (por ejemplo, alto, medio, bajo), o

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) cuantitativos, mediante una escala con valores numéricos (por ejemplo, costo monetario, frecuencia o probabilidad matemática de ocurrencia), o

c) semicuantitativo, mediante escalas cualitativas con valores asignados.

El análisis del riesgo debería dirigirse a aquellos riesgos y controles que, si se gestionan con éxito, mejoran la probabilidad de que la organización alcance sus objetivos. Es fácil dedicar un tiempo considerable a una evaluación de riesgos, especialmente a la evaluación de probabilidades y consecuencias. Para permitir una toma de decisiones eficaz sobre la gestión de riesgos, puede ser suficiente utilizar estimaciones iniciales y aproximadas de probabilidad y consecuencia.

7.3.2 Evaluación de posibles consecuencias

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem d) 1).

Insumo: una lista de escenarios de eventos o riesgos relevantes identificados, que incluya la identificación de las fuentes de riesgo, y los procesos empresariales, objetivos empresariales y criterios de consecuencia. Además, listas de todos los controles existentes, su eficacia y su estado de implementación y utilización.

Acción: se deberían identificar y evaluar las consecuencias derivadas de no preservar adecuadamente la confidencialidad, integridad o disponibilidad de la información.

Desencadenante: La evaluación de las consecuencias se hace necesaria cuando:

- no se haya hecho antes;
- la lista producida por la “identificación del riesgo” haya cambiado;
- los propietarios del riesgo o las partes interesadas hayan cambiado las unidades en las que quieren que se especifiquen las consecuencias, o
- se hayan determinado cambios en el campo de aplicación o el contexto que afecten a las consecuencias.

Resultado: una lista de consecuencias potenciales relacionadas con las hipótesis de riesgo, con sus consecuencias sobre los activos o los eventos, dependiendo del enfoque aplicado.

Orientación para la implementación:

Si no se preserva adecuadamente la seguridad de la información, se puede perder su confidencialidad, integridad o disponibilidad. Esta pérdida de confidencialidad, integridad o disponibilidad puede tener otras consecuencias para la organización y sus objetivos. El análisis de consecuencias se puede realizar en sentido ascendente, a partir de las consecuencias para la seguridad de la información, mediante la consideración de qué puede ocurrir si se produce una pérdida de confidencialidad, integridad o disponibilidad de la información en cuestión. Normalmente, el propietario del riesgo puede estimar la consecuencia de que se produzca el evento. Se deberían tomar en consideración los siguientes aspectos:

- Estimación (o medida basada en la experiencia) de las pérdidas (de tiempo o de datos) provocadas por el evento, como resultado de la interrupción o perturbación de las operaciones.
- Estimación/percepción de la gravedad de la consecuencia (por ejemplo, expresada en dinero).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Costos de recuperación, dependiendo de si la recuperación puede hacerse internamente (por el equipo del propietario del riesgo) o si es necesario llamar a una entidad externa.

7.3.3 Evaluación de la probabilidad

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem d) 2).

Insumo: una lista de los escenarios de eventos o riesgos relevantes identificados, que incluya la identificación de las fuentes de riesgo, y los procesos empresariales, objetivos empresariales y criterios de probabilidad. Además, listas de todos los controles existentes, su eficacia y su estado de implementación y utilización.

Acción: se debería evaluar y expresar, mediante criterios de probabilidad establecidos, la probabilidad de que se produzcan escenarios posibles o reales.

Desencadenante: la evaluación de la probabilidad es, junto con la de la consecuencia, una actividad clave del proceso de evaluación del riesgo al momento de determinar el nivel de riesgo.

La evaluación de la probabilidad es necesaria cuando:

- No se ha hecho antes.
- Se hayan determinado cambios en el campo de aplicación o el contexto que pueden afectar a la probabilidad.
- Se descubran vulnerabilidades en los controles aplicados.
- Los ensayos / las auditorías de la eficacia de los controles producen resultados inesperados.
- Se descubren cambios en el entorno de amenazas (por ejemplo, nuevos actores o fuentes de amenaza).

Resultado: una lista de eventos o escenarios de riesgo, complementada con las probabilidades de que éstos se produzcan.

Orientación para la implementación:

Después de identificar los escenarios de riesgo, es necesario analizar la probabilidad de que ocurra cada escenario y consecuencia, utilizando técnicas de análisis cualitativo o cuantitativo. Evaluar la probabilidad no siempre es fácil, y se debería expresar de diferentes maneras. Se debería tomar en consideración la frecuencia con que se producen las fuentes de riesgo o la facilidad con que pueden aprovecharse algunas de ellas (por ejemplo, las vulnerabilidades), considerando:

- La experiencia y las estadísticas aplicables sobre la probabilidad de las fuentes de riesgo.
- Para las fuentes de riesgo intencionales: el grado de motivación [por ejemplo, la viabilidad (costo/ beneficio) del ataque] y las capacidades (por ejemplo, el nivel de habilidad de los posibles atacantes), que cambian con el tiempo; los recursos disponibles para los posibles atacantes, y las influencias sobre los posibles atacantes, tales como la delincuencia grave, las organizaciones terroristas o la inteligencia extranjera, así como la percepción del atractivo y la vulnerabilidad de la información para un posible atacante.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Para las fuentes de riesgo accidental: factores geográficos (por ejemplo, proximidad a instalaciones o actividades peligrosas), posibilidad de catástrofes naturales como condiciones meteorológicas extremas, actividad volcánica, terremotos, inundaciones, tsunamis y factores que puedan incidir en los errores humanos y el mal funcionamiento de los equipos.

- Deficiencias conocidas y los controles de compensación, tanto individualmente como en grupo.

- Los controles existentes y su eficacia para reducir los puntos débiles conocidos.

El cálculo de la probabilidad es intrínsecamente incierto, no solamente porque tiene en cuenta cosas que aún no han sucedido y, por tanto, no se conocen del todo, sino también porque la probabilidad es una medida estadística, y no es directamente representativa de eventos individuales. Las tres fuentes básicas de incertidumbre en la evaluación son:

- Incertidumbre personal que se origina en el criterio del evaluador, que se deriva de la variabilidad de la heurística mental de la toma de decisiones.

- Incertidumbre metodológica, la cual se deriva del uso de herramientas que, inevitablemente, modelan los eventos de forma simplista.

- Incertidumbre sistémica sobre el evento previsto en sí, la cual se deriva de un conocimiento insuficiente (en particular, si las pruebas son limitadas o si una fuente de riesgo cambia con el tiempo).

Para aumentar la fiabilidad en la estimación de la probabilidad, las organizaciones deberían considerar el uso de:

a) Evaluaciones en equipo, en lugar de evaluaciones individuales.

b) Fuentes externas, como informes sobre violaciones de la seguridad de la información.

c) Escalas con un rango y una resolución adecuados para el enfoque de la organización.

d) Categorías inequívocas, como "una vez al año", en lugar de "infrecuente".

Al evaluar la probabilidad de los sucesos, es importante reconocer la diferencia entre eventos independientes y dependientes. La probabilidad de los eventos que dependen unos de otros está condicionada por la relación entre ellos (por ejemplo, un segundo evento puede ser inevitable si se produce un primer evento), de modo que no es necesario evaluar por separado la posibilidad de ambos. Todas las probabilidades de eventos independientes relevantes contribuyen de forma esencial a la probabilidad de una consecuencia a la que contribuyen.

EJEMPLO La probabilidad de un ataque de denegación de servicio a un servidor depende del panorama actual de amenazas y de la vulnerabilidad y accesibilidad del servidor. Sin embargo, la probabilidad de paquetes maliciosos puede ser del 100 % una vez iniciado el ataque, y su evaluación no ayuda a evaluar la probabilidad del ataque de denegación de servicio.

Para evitar una complejidad innecesaria de la evaluación, es importante identificar cualquier dependencia entre los eventos que contribuyen a un escenario de riesgo y, en primer lugar, evaluar las probabilidades de aquellos eventos que son independientes entre sí.

La probabilidad global de las consecuencias empresariales de un evento de seguridad de la información suele depender de la probabilidad de, potencialmente, varios sucesos contribuyentes de nivel inferior y de sus consecuencias. En lugar de intentar estimar la probabilidad de las consecuencias empresariales

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

en una única evaluación de alto nivel, puede ser más válido empezar agregando las probabilidades de los sucesos de nivel inferior, evaluados individualmente, que contribuyen a ello.

7.3.4 Determinación de los niveles de riesgo

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2. ítem d) 3).

Insumo: una lista de escenarios de riesgo, con sus consecuencias relacionadas con activos o eventos, y su probabilidad (cuantitativa o cualitativa).

Acción: el nivel de riesgo debería determinarse como una combinación de la probabilidad evaluada y las consecuencias evaluadas, para todos los escenarios de riesgo pertinentes.

Desencadenante: la determinación de los niveles de riesgo es necesaria si se van a valorar los riesgos para la seguridad de la información.

Resultado: una lista de riesgos con valores de nivel asignados.

Orientación para la implementación:

El nivel de riesgo se puede determinar de muchas maneras posibles. Por lo general, se determina como una combinación de la probabilidad evaluada y las consecuencias evaluadas, para todos los escenarios de riesgo pertinentes. Los cálculos alternativos pueden incluir un valor del activo, en adición a la probabilidad y las consecuencias. Por otra parte, el cálculo no es necesariamente lineal, por ejemplo, puede ser la probabilidad al cuadrado combinada con la consecuencia. En cualquier caso, el nivel de riesgo se debería determinar según los criterios establecidos según se describe en el numeral 6.4.3.4.

7.4 Valoración de los riesgos para la seguridad de la información

7.4.1 Comparación de los resultados del análisis del riesgo con los criterios de riesgo

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem e) 1).

Insumo: una lista de criterios de riesgo y de riesgos con sus valores de nivel asignados.

Acción: el nivel de riesgo se debería comparar con los criterios de valoración del riesgo, en particular con los criterios de aceptación del riesgo.

Desencadenante: la comparación de los resultados del análisis del riesgo con los criterios de riesgo es imprescindible si se van a priorizar riesgos para la seguridad de la información para su tratamiento.

Resultado: una lista de sugerencias para tomar decisiones sobre acciones adicionales respecto a la gestión de riesgos.

Orientación para la implementación:

Después de haber identificado los riesgos y de haber asignado valores de probabilidad y de gravedad de las consecuencias, las organizaciones deberían aplicar sus criterios de aceptación de riesgos para determinar si los riesgos pueden aceptarse o no. Si no se pueden aceptar, se les debería priorizar para su tratamiento.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Para valorar los riesgos, las organizaciones deberían comparar los riesgos evaluados con los criterios de riesgo definidos durante el establecimiento del contexto.

Las decisiones de valoración del riesgo deberían basarse en la comparación del riesgo evaluado con los criterios de aceptación definidos, a ser posible, tomando en consideración el grado de confianza en la evaluación. En algunos casos, como la ocurrencia frecuente de sucesos de consecuencias relativamente bajas, puede ser útil considerar su efecto acumulativo a lo largo respecto a una escala de tiempo de interés, en lugar del riesgo de cada evento considerado individualmente, ya que esto puede ofrecer una representación más realista de los riesgos globales.

Puede haber incertidumbres al definir el límite entre los riesgos que requieren tratamiento y los que no. En determinadas circunstancias, no siempre es adecuado utilizar un único nivel como nivel aceptable de riesgo que divida los riesgos que requieren tratamiento de los que no. En algunos casos, puede resultar más eficaz incluir un elemento de flexibilidad en los criterios mediante la incorporación de parámetros adicionales, como el costo y la eficacia de los posibles controles.

Los niveles de riesgo pueden validarse sobre la base del consenso entre los propietarios del riesgo y los especialistas técnicos y empresariales. Es importante que los propietarios de los riesgos tengan una buena comprensión de los riesgos por los que rinden cuentas que concuerde con los resultados de la evaluación objetiva. Por consiguiente, se debería investigar cualquier disparidad entre los niveles de riesgo evaluados y los percibidos por los propietarios del riesgo, para determinar cuál se aproxima más a la realidad.

7.4.2 Priorización de los riesgos analizados para el tratamiento del riesgo

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.2, ítem e) 2).

Insumo: una lista de los resultados de los riesgos comparados con los criterios de riesgo.

Acción: los riesgos de la lista se deberían priorizar para el tratamiento del riesgo, tomando en consideración los niveles de riesgo evaluados.

Desencadenante: la priorización de los riesgos analizados para el tratamiento del riesgo es indispensable si se van a tratar los riesgos para la seguridad de la información.

Resultado: una lista de riesgos priorizados, con los escenarios de riesgo que producen tales riesgos.

Orientación para la implementación:

La valoración del riesgo utiliza la comprensión del riesgo, obtenida mediante el análisis del riesgo, para hacer propuestas que permitan decidir el siguiente paso a dar. Éstas deberían referirse a:

- Si se requiere un tratamiento del riesgo.
- Prioridades para el tratamiento del riesgo, tomando en consideración los niveles de riesgo evaluados.

Los criterios de riesgo que se utilizan para priorizar los riesgos deberían considerar los objetivos de la organización, los requisitos contractuales, legales y reglamentarios, y las opiniones de las partes interesadas pertinentes. La priorización adoptada en la actividad de valoración del riesgo se basa principalmente en los criterios de aceptación.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

8 PROCESO DE TRATAMIENTO DEL RIESGO PARA LA SEGURIDAD DE LA INFORMACIÓN

8.1 Generalidades

El insumo del tratamiento del riesgo para la seguridad de la información se basa en los resultados del proceso de evaluación de riesgos en forma de una serie priorizada de riesgos a tratar, basada en criterios de riesgo.

El resultado de este proceso es una serie de controles de seguridad de la información necesarios [véase el numeral 6.1.3, entrada b), de la NTC-ISO/IEC 27001:2022] que se desplegarán o mejorarán entre sí, de acuerdo con el plan de tratamiento del riesgo [véase el numeral 6.1.3, entrada e), de la NTC-ISO/IEC 27001:2022]. Desplegado de esta manera, la eficacia del plan de tratamiento del riesgo es modificar el riesgo de seguridad de la información al que se enfrenta la organización para que cumpla con los criterios de aceptación de la organización.

8.2 Selección de las opciones adecuadas de tratamiento del riesgo para la seguridad de la información

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.3, ítem a).

Insumo: una lista de riesgos priorizados, con los escenarios de eventos o riesgos que conduzcan a tales riesgos.

Acción: se deberían elegir opciones de tratamiento del riesgo.

Desencadenante: la selección de las opciones adecuadas de tratamiento del riesgo para la seguridad de la información indispensable si no existe un plan de tratamiento del riesgo o si el plan está incompleto.

Resultado: una lista de riesgos priorizados, con las opciones de tratamiento del riesgo seleccionadas.

Orientación para la implementación:

Entre las diversas opciones de tratamiento del riesgo se encuentran:

- Evasión del riesgo, mediante la decisión de no iniciar o continuar la actividad que da lugar al riesgo.
- Modificación del riesgo, mediante la modificación de la probabilidad de que ocurra un suceso o una consecuencia, o la modificación de la gravedad de la consecuencia.
- Retención del riesgo, mediante una elección informada.
- Compartir del riesgo, mediante la división de responsabilidades con otras partes, ya sea interna o externamente (por ejemplo, distribución de las consecuencias mediante un seguro).

EJEMPLO 1 Un ejemplo de evasión del riesgo es la ubicación de una oficina en una zona inundable, donde existe la posibilidad de que se produzca una inundación, con los consiguientes daños a la oficina y las restricciones a la disponibilidad de la oficina o al acceso a la misma. Los controles físicos pertinentes pueden resultar insuficientes para reducir este riesgo, en cuyo caso la opción de tratamiento de evasión del riesgo puede ser la mejor opción disponible. Esto puede implicar el cierre o la interrupción del funcionamiento de esa oficina.

EJEMPLO 2 Otro ejemplo de prevención de riesgos es optar por no recolectar determinada información de las personas, de modo que no sea necesario que la organización gestione, almacene y transmita la información en sus sistemas de información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

En caso de repartir el riesgo, se requiere al menos un control para modificar la probabilidad o la consecuencia, pero la organización delega en otra parte la responsabilidad de implementar el control.

Las opciones de tratamiento del riesgo se deberían seleccionar a partir del resultado de la evaluación del riesgo, los costos esperados para implementar estas opciones y los beneficios esperados de estas opciones, tanto individualmente como en el contexto de otros controles. El tratamiento del riesgo se debería priorizar de acuerdo con los niveles de riesgo definidos, con las limitaciones de tiempo y la secuencia necesaria de las implementaciones, y con los resultados de la valoración del riesgo establecidos en el numeral 7.4. Al escoger la opción, se puede considerar la forma en que las partes afectadas perciben un riesgo determinado, y las formas más adecuadas de comunicar el riesgo a tales partes.

8.3 Determinación de todos los controles necesarios para aplicar las opciones de tratamiento del riesgo para la seguridad de la información

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.3, ítem b).

Insumo: una lista de riesgos priorizados, con las opciones de tratamiento del riesgo seleccionadas.

Acción: determinar todos los controles, tomados de las series de controles elegidas, seleccionadas de una fuente apropiada, que son necesarios para tratar los riesgos, en función de las opciones de tratamiento del riesgo elegidas, tales como modificar, retener, evadir o distribuir los riesgos.

Desencadenante: conformidad con el SGSI; gestión de los riesgos para la seguridad de la información.

Resultado: todos los controles necesarios.

Orientación para la implementación:

Se debería prestar especial atención a la determinación de los controles necesarios. Se debería comprobar cada control para determinar si es necesario, mediante las siguientes preguntas:

- ¿Qué efecto tiene este control sobre la probabilidad o la consecuencia de este riesgo?
- ¿De qué manera el control mantiene el nivel de riesgo?

Únicamente los controles que tengan un efecto más que insignificante sobre el riesgo deberían designarse como "necesarios". Se debería aplicar uno o más controles a cada riesgo valorado como que requiere tratamiento.

Hay muchas fuentes para los conjuntos de controles. Se pueden encontrar en el Anexo A de la NTC-ISO/IEC 27001:2022, en códigos de prácticas específicos del sector (como la GTC-ISO/IEC 27017) y en otros conjuntos de controles nacionales, regionales e industriales. Una organización también puede determinar uno o varios controles “personalizados” (véase la GTC-ISO/IEC 27003).

Si se define un control personalizado, el enunciado del control debería describir con precisión y equidad cuál es el control y cómo funciona. Según corresponda y sea apropiado, esta redacción puede incluir aspectos tales como:

- Si es un control documentado.
- A quién pertenece el control.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Cómo se monitorea.
- Cómo se puede evidenciar.
- Cualquier excepción.
- La frecuencia de aplicación del control.
- La tolerancia del control.
- Si no es evidente, la razón por la que existe el control.

Si el control está fuera de la tolerancia, el control no funciona con la eficacia suficiente para gestionar el riesgo identificado.

EJEMPLO 1 "Existe un proceso documentado de gestión de *malware*, propiedad del gerente de seguridad de TI. Esto excluye a computadores Mac, y se monitorea a través de la consola del proveedor, con informes sobre el desempeño que se envían semanalmente al CIO".

Este enfoque al detalle en la redacción de los controles puede ser útil si los controles personalizados también se destinan a apoyar a la organización en la elaboración de informes de aseguramiento del control. Sin embargo, es más importante que la redacción de los controles debería tener significado para las personas de la organización y les ayude a tomar decisiones sobre la gestión de esos controles y de los riesgos asociados.

La determinación de los controles puede incluir nuevos controles que todavía no estén implementados, o puede incluir el uso de controles que ya existen en la organización. Sin embargo, un control que ya esté en funcionamiento no debería incluirse automáticamente en la evaluación de riesgos ya que:

- el control no es necesario para gestionar uno o más riesgos para la seguridad de la información;
- puede ser un control que ayude, de alguna manera, a gestionar uno o más riesgos para la seguridad de la información, pero no es lo suficientemente eficaz como para ser incluido en la evaluación de riesgos o para ser gestionado por el SGSI o
- puede estar funcionando actualmente por razones no relacionadas con la seguridad de la información (por ejemplo, calidad, eficiencia, eficacia o cumplimiento), o
- funciona actualmente, pero, desde el punto de vista de la seguridad de la información, puede suprimirse al no tener un efecto suficiente que justifique su mantenimiento como control esencial.

Si un control se utiliza para otros fines que no sean únicamente la gestión de los riesgos para la seguridad de la información, se debería tener cuidado de asegurar que el control se gestione para alcanzar los objetivos de seguridad de la información, así como los objetivos no relacionados con la seguridad de la información.

EJEMPLO 2 Un circuito cerrado de televisión interno para el control de la calidad del proceso de producción, así como por motivos de seguridad de la información (como protección contra el fraude).

Al determinar los controles en un conjunto de controles existentes (por ejemplo, del Anexo A de la NTC-ISO/IEC 27001:2022, o de una lista de controles específica del sector), la redacción del control debería coincidir con lo que es necesario para gestionar el riesgo y reflejar con exactitud qué es o debería ser el control. Si el enfoque general es utilizar un conjunto de controles existentes (por ejemplo, el Anexo A de la NTC-ISO/IEC 27001:2022 o una lista de controles específica del sector) y el conjunto

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

de controles no contiene ninguno que describa con exactitud el control necesario, se debería considerar definir un control personalizado que describa con exactitud el control.

Los controles pueden clasificarse en controles de prevención, de detección y de corrección:

a) Control de prevención: control destinado a prevenir que se produzca un evento de seguridad de la información que pueda generar una o varias consecuencias.

b) Control de detección: control destinado a detectar la ocurrencia de un evento de seguridad de la información.

c) Control de corrección: control destinado a limitar las consecuencias de un evento de seguridad de la información.

El tipo de control describe si un control actúa, o pretende actuar, para prevenir o detectar un evento o para reaccionar ante sus consecuencias.

EJEMPLO 3 Una política de seguridad de la información es un control que mantiene el riesgo, pero la conformidad con la política tiene por finalidad reducir la probabilidad de que se produzca el riesgo, por lo que puede clasificarse como preventivo.

La utilidad de categorizar los controles como de prevención, detección y corrección radica en su uso, para garantizar que la construcción de planes de tratamiento del riesgo sea resiliente frente a las fallas de control. Mientras exista una combinación adecuada de controles de prevención, detección y corrección:

- Los controles de detección deberían mitigar el riesgo si fallan los controles de prevención.
- Los controles de corrección deberían mitigar el riesgo si fallan los controles de detección.
- Los controles de prevención deberían reducir la probabilidad de que sea necesario recurrir a los controles de corrección.

A la hora de utilizar controles, las organizaciones deberían, en primer lugar, decidir si es posible detectar la ocurrencia de un evento. Si es así, deberían aplicarse controles de detección. Si no es posible detectar un evento, los controles de detección pueden resultar ineficaces, sin tener cómo saber si un control de prevención funciona.

EJEMPLO 4 Si no está claro si un computador ha pasado a formar parte de una red de robots, no se puede saber si los controles que se están utilizando para evitar que forme parte de una red de robots funcionan según lo previsto.

Los controles de detección pueden funcionar adecuadamente, pero seguir siendo ineficaces.

EJEMPLO 5 La implementación de sistemas de detección/prevención de intrusiones puede ser una forma eficaz de evitar que el *malware* atraviese la red, pero no sirven de nada si no hay un monitoreo de los sistemas/alertas para actuar en caso de que se produzca un brote que no se contenga.

En general, los controles de detección son, en última instancia, ineficaces en los casos en que se puedan eludir, o cuando su notificación no produce la acción apropiada. Los controles de corrección deberían considerarse a continuación. Si fallan los controles de detección, es probable que se produzcan una o varias consecuencias indeseables. La aplicación de los controles de corrección puede ayudar a limitar esas consecuencias. Aunque estos controles surten efecto después de que se produzca la consecuencia, a menudo es necesario implementarlos mucho antes de que se produzca un evento.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

EJEMPLO 6 El cifrado del disco duro no impide el robo de un portátil ni los intentos posteriores para extraer los datos. Sin embargo, reduce la gravedad de las consecuencias ligadas a una divulgación. El control, naturalmente, necesita desplegarse antes de que se produzca el robo del portátil.

La categorización de los controles no es absoluta, y depende del contexto en el que se describe el uso de un control.

EJEMPLO 7 La copia de respaldo no evita que se produzca un evento que, de otro modo, provocaría la pérdida de datos (por ejemplo, la rotura de un cabezal en un disco o la pérdida de un portátil), pero ayuda a reducir las consecuencias. Por ello, algunas organizaciones pueden considerarlo un control de corrección más que uno de prevención. Del mismo modo, el cifrado no evita la pérdida de información, pero si el evento se describe como “datos personales revelados a un atacante”, entonces el cifrado es un control de prevención más que uno de corrección.

El orden en que se organizan los controles que abordan los riesgos depende de varios factores. Se pueden utilizar muchas técnicas. Corresponde a los respectivos propietarios del riesgo decidir el equilibrio entre los costos de invertir en controles y asumir las consecuencias en caso de que los riesgos se materialicen.

La identificación de los controles existentes puede determinar que estos controles superan las necesidades actuales. Antes de suprimir controles redundantes o innecesarios debería realizarse un análisis de costo-beneficio (especialmente si los controles tienen elevados costos de mantenimiento). Dado que los controles pueden ejercer una influencia mutua, la supresión de controles redundantes puede reducir la seguridad general existente. Los controles no deberían incluirse en el tratamiento del riesgo a menos que sean controles necesarios para gestionar uno o más de los riesgos para la seguridad de la información identificados. Un control debería tener un efecto sobre la consecuencia o la probabilidad de los riesgos para la seguridad de la información identificados. Los controles no deberían incluirse en el tratamiento del riesgo si funcionan por razones no relacionadas con la seguridad de la información.

Se deberían tomar en consideración los controles que se aplican pero que se sabe que presentan algunos puntos débiles. Si la evaluación de todos los riesgos que gestiona un control con puntos débiles está dentro de los criterios de aceptación, no es necesario mejorar el control. Aunque el control no funcione con plena eficacia, no siempre es necesario mejorarlo para que sea totalmente eficaz. No se debería suponer que es muy importante que los controles funcionen con plena eficacia para que la organización gestione sus riesgos con éxito. Es posible especificar que cada control individual tiene un nivel de tolerancia al error por debajo del cual puede considerarse que el control no funciona con suficiente eficacia para gestionar los riesgos identificados. Mientras el control funcione dentro de la tolerancia, no necesita ninguna mejora.

8.4 Comparación de los controles determinados con los del Anexo A de la NTC-ISO/IEC 27001:2022

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.3, ítem c).

Insumo: todos los controles necesarios (véase el numeral 8.3).

Acción: comparar todos los controles necesarios con los del Anexo A de la NTC-ISO/ IEC 27001:2022.

Desencadenante: la identificación de los controles faltantes es indispensable si se formulan planes de tratamiento del riesgo.

Resultado: todos los controles aplicables al tratamiento del riesgo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Orientación para la implementación:

El numeral 6.1.3. entrada c), de la NTC-ISO/IEC 27001:2022, requiere que una organización compare los controles que ha determinado como necesarios para aplicar las opciones de tratamiento del riesgo que eligió con los controles enumerados en el Anexo A de la NTC-ISO/IEC 27001:2022. Esto tiene por finalidad actuar como un control de seguridad para verificar que no se ha omitido ningún control necesario en la evaluación del riesgo. Esta verificación de seguridad no se realiza para identificar la omisión de algún control del Anexo A de la NTC-ISO/IEC 27001:2022 en la evaluación de riesgos. Se trata de un control de seguridad para identificar cualquier control necesario omitido, de cualquier fuente, mediante la comparación de los controles con otras normas y listas de controles. Los controles omitidos identificados durante esta verificación pueden ser controles específicos del sector, controles personalizados, o controles del Anexo A de la NTC-ISO/IEC 27001:2022. Se deberían seguir las directrices del numeral 8.3 para determinar los controles cuando se considere si se deberían agregar controles omitidos a la evaluación de riesgos.

EJEMPLO Es importante que un control que ya esté funcionando en la organización no se incorpore automáticamente a la evaluación de riesgos sin someterlo a mayor consideración.

Es importante recordar que esta comparación de los controles se realiza mediante la evaluación de riesgos, y no mediante la declaración de aplicabilidad. El principio es examinar cada riesgo por separado y comparar los controles determinados como necesarios para el riesgo con los controles del Anexo A de la NTC-ISO/IEC 27001:2022 para determinar si falta algún control necesario para cada riesgo.

8.5 Elaboración de una declaración de aplicabilidad

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.3, ítem d).

Insumo: todos los controles aplicables al tratamiento del riesgo (véase el numeral 8.4).

Acción: elaborar una declaración de aplicabilidad.

Desencadenante: la documentación de todos los controles requeridos, su justificación y su estado de aplicación.

Resultado: declaración de aplicabilidad.

Orientación para la implementación:

De acuerdo con el numeral 6.1.3, ítem d), de la NTC-ISO/IEC 27001:2022, la declaración de aplicabilidad (SOA, por sus siglas en inglés) debería contener, como mínimo:

a) Los controles necesarios.

b) La justificación de su inclusión.

c) Si se implementan o no.

d) La justificación para la exclusión de controles del Anexo A de la NTC-ISO/IEC 27001:2022.

La SOA se puede elaborar fácilmente si se examina la evaluación de riesgos para identificar los controles necesarios, y el plan de tratamiento del riesgo, para identificar los controles que está previsto implementar. Solo pueden incluirse en la SOA los controles identificados en la evaluación de riesgos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

No se pueden añadir controles a la SOA independientemente de la evaluación de riesgos. Debería haber consistencia entre los controles necesarios para ejecutar las opciones de tratamiento del riesgo seleccionadas y la SOA. La SOA puede declarar que la justificación para la inclusión de un control es la misma para todos los controles, y que estos han sido identificados en la evaluación de riesgos como necesarios para tratar uno o más riesgos a un nivel aceptable. No se requiere una justificación adicional para la inclusión de un control. El estado de la implementación de todos los controles contenidos en la SOA puede declararse como “implementado”, “parcialmente implementado” o “no implementado”. Esto puede hacerse individualmente para cada control, o bien como una declaración general.

EJEMPLO La SOA contiene la siguiente declaración: “Se han implementado todos los controles”. No se requiere ningún análisis o información adicionales para completar la SOA.

8.6 Plan de tratamiento del riesgo para la seguridad de la información

8.6.1 Formulación del plan de tratamiento del riesgo

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.3, ítem e).

Insumo: resultados de las evaluaciones de riesgos.

Acción: formulación del plan de tratamiento del riesgo.

Desencadenante: la necesidad de la organización de tratar los riesgos.

Resultado: plan de tratamiento del riesgo.

Orientación para la implementación:

El propósito de esta actividad es crear uno o varios planes para tratar conjuntos específicos de riesgos que figuran en la lista de riesgos priorizados (véase el numeral 7). Un plan de tratamiento del riesgo es un plan destinado a modificar el riesgo para que este cumpla con los criterios de aceptación de riesgos de la organización (véase el numeral 6.4.2). En el contexto del tratamiento del riesgo existen dos posibles interpretaciones del término “plan”. La primera es un plan de proyecto, es decir, un plan para implementar los controles necesarios de la organización. La segunda es un plan de diseño, es decir, el plan que no solamente identifica los controles necesarios, sino que también describe cómo interactúan los controles con su entorno y entre sí para modificar los riesgos. En la práctica, se pueden utilizar ambos.

Una vez implementados los controles, el plan del proyecto deja de tener valor salvo como registro histórico, mientras que el plan de diseño sigue siendo útil.

Todo riesgo que necesite tratamiento debería tratarse en uno de los planes de tratamiento del riesgo. Una organización puede decidir tener varios planes de tratamiento del riesgo que, en conjunto, implementen todos los aspectos requeridos del tratamiento del riesgo. Estos planes pueden organizarse en función de dónde reside la información (por ejemplo, un plan para el centro de datos, otro para la informática móvil, entre otros), por activos (por ejemplo, diferentes planes para diferentes clasificaciones de activos) o por eventos (como los utilizados al evaluar el riesgo mediante el método basado en eventos).

Al crear el plan de tratamiento del riesgo, las organizaciones deberían considerar lo siguiente:

- Las prioridades en relación con el nivel de riesgo y la urgencia del tratamiento.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Si son aplicables diferentes tipos de controles (de prevención, de detección, de corrección) o sus combinaciones.
- Si es necesario esperar a que se liquide un control antes de empezar a aplicar uno nuevo sobre el mismo activo.
- Si existe un retraso entre el momento en que se implementa el control y el momento en que es plenamente efectivo y operativo.

Para cada riesgo tratado, el plan de tratamiento debería incluir la siguiente información:

- La justificación de la selección de las opciones de tratamiento, incluidos los beneficios que se espera obtener.
- Las personas responsables y que tienen que rendir cuentas de la aprobación y aplicación del plan.
- Las acciones propuestas.
- Los recursos necesarios, considerando los imprevistos.
- Los indicadores de resultados.
- Las limitaciones.
- Los informes y el monitoreo necesarios.
- Cuándo se espera que se emprendan y completen las acciones.
- El estado de implementación.

Las acciones del plan de tratamiento del riesgo deberían clasificarse por orden de prioridad en relación con el nivel de riesgo y la urgencia del tratamiento. Cuanto mayor sea el nivel de riesgo y, en algunos casos, la frecuencia de ocurrencia del riesgo, antes se aplicará el control.

Para cada riesgo enumerado en el plan de tratamiento del riesgo, se debería hacer un seguimiento de la información detallada sobre su aplicación, que puede contener, entre otros datos:

- Nombres de los propietarios del riesgo y de las personas responsables de la aplicación.
- Fechas o plazos de aplicación.
- Las actividades de control planeadas para verificar el resultado de la aplicación.
- El estado de implementación.
- El nivel de costos (inversión, funcionamiento).

8.6.2 Aprobación por los propietarios del riesgo

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.3, ítem f).

I**nsumo**: plan(es) de tratamiento del riesgo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Acción: aprobación del o de los planes de tratamiento del riesgo por los propietarios del riesgo.

Desencadenante: la necesidad de que se apruebe el o los planes de tratamiento del riesgo.

Resultado: planes de tratamiento del riesgo aprobados.

Orientación para la implementación:

Una vez formulado, el plan de tratamiento del riesgo para la seguridad de la información debería ser aprobado por los propietarios del riesgo. Los propietarios del riesgo también deberían decidir sobre la aceptación de los riesgos residuales para la seguridad de la información. Esta decisión debería basarse en criterios definidos de aceptación de riesgos.

Los resultados de la evaluación de riesgos, el plan de tratamiento del riesgo y los riesgos restantes deberían ser comprensibles para los propietarios del riesgo, de modo que puedan liberarse adecuadamente de la rendición de cuentas.

8.6.3 Aceptación de los riesgos residuales para la seguridad de la información

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 6.1.3, ítem f).

Insumo: plan(es) de tratamiento del riesgo aprobado(s) y criterios de aceptación del riesgo.

Acción: determinar si los riesgos residuales son aceptables.

Desencadenante: la necesidad de que la organización decida si retener los riesgos residuales.

Resultado: riesgos residuales aceptados.

Orientación para la implementación:

Para determinar los riesgos residuales, los planes de tratamiento del riesgo deberían alimentar la evaluación de seguimiento de la probabilidad y consecuencia residuales. Los controles propuestos, descritos en los planes de tratamiento del riesgo, y su eficacia se deberían considerar en función de si reducirán la probabilidad o la consecuencia, o ambas, y de si el nivel de riesgos residuales se asigna a los riesgos. A continuación, el propietario del riesgo analiza el nivel de los riesgos residuales, para determinar si son aceptables.

Los planes de tratamiento del riesgo deberían describir cómo se van a tratar los riesgos evaluados para cumplir con los criterios de aceptación de riesgos.

En algunos casos, el nivel de riesgo residual no siempre cumple con los criterios de aceptación de riesgos, porque los criterios que se aplican no toman en consideración las circunstancias imperantes.

EJEMPLO Se puede afirmar que es necesario conservar los riesgos porque los beneficios que los acompañan constituyen una importante oportunidad de negocio, o porque el costo de la modificación del riesgo es demasiado elevado.

Sin embargo, no siempre es posible revisar a tiempo los criterios de aceptación del riesgo. En tales casos, los propietarios del riesgo pueden retener riesgos que no cumplan con los criterios normales de aceptación. Si esto es necesario, el propietario del riesgo debería comentar explícitamente los riesgos e incluir una justificación de la decisión de ignorar los criterios normales de aceptación del riesgo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La aceptación del riesgo puede conllevar un proceso para lograr la aprobación de tratamientos antes de la decisión final de aceptación del riesgo. Es importante que los propietarios del riesgo revisen y aprueben los planes de tratamiento del riesgo propuestos y los riesgos residuales resultantes, así como que registren cualquier condición asociada a dicha aprobación. Dependiendo del proceso de evaluación de riesgos y los criterios de aceptación de riesgos, esto puede requerir que un directivo con un nivel de autoridad superior al del propietario del riesgo dé su visto bueno a la aceptación del riesgo.

La implementación de un plan para tratar los riesgos evaluados puede tomar un tiempo. Los criterios de riesgo pueden permitir que los niveles de riesgo superen un límite deseado, hasta un punto definido, si existe un plan para reducir ese riesgo en un tiempo aceptable. Las decisiones de aceptación del riesgo pueden tomar en consideración los plazos de los planes de tratamiento del riesgo y si el progreso de la aplicación del tratamiento del riesgo cumple o no con lo previsto.

Algunos riesgos pueden variar con el paso del tiempo (independientemente de que este cambio se deba a la aplicación de un plan de tratamiento del riesgo). Los criterios de aceptación del riesgo pueden tomar esto en consideración y tener límites de aceptación del riesgo que dependan del tiempo que una organización puede estar expuesta a un riesgo evaluado.

9 OPERACIÓN

9.1 Ejecución del proceso de evaluación de riesgos para la seguridad de la información

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 8.2.

Insumo: documentos sobre el proceso de evaluación de riesgos para la seguridad de la información, incluidos la evaluación de riesgos y los criterios de aceptación del riesgo.

Acción: el proceso de evaluación de riesgos se debería llevar a cabo de acuerdo con lo descrito en el numeral 7.

Desencadenante: la necesidad de la organización de evaluar los riesgos, a intervalos programados o en función de los eventos.

Resultado: riesgos valorados.

Orientación para la implementación:

El proceso de evaluación de riesgos para la seguridad de la información, definido y aplicado en el numeral 6.1 de la NTC-ISO/IEC 27001:2022, debería integrarse a las operaciones de la organización, y debería realizarse a intervalos planificados o cuando se propongan o se produzcan cambios significativos. El proceso de evaluación de riesgos para la seguridad de la información debería tomar en cuenta los criterios establecidos en el numeral 6.1.2, entrada a), de la NTC-ISO/IEC 27001:2022. Los intervalos en los que se realiza la evaluación de riesgos deberían ser apropiados para el SGSI. Cuando se ha producido un cambio significativo en el SGSI (o en su contexto) o un cambio en el panorama de amenazas (por ejemplo, un nuevo tipo de ataque a la seguridad de la información), la organización debería determinar si este cambio requiere una evaluación adicional de los riesgos para la seguridad de la información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Al planificar las evaluaciones rutinarias de riesgos, las organizaciones deberían tener en cuenta cualquier calendario que se aplique a sus procesos empresariales generales y a los ciclos presupuestarios asociados.

EJEMPLO Si existe un ciclo presupuestario anual, se puede exigir a la organización que presente solicitudes de financiamiento en un determinado momento del año. Los fondos se conceden (se reducen o se niegan) posteriormente.

Si hay procesos de adquisición implicados, puede haber otro ciclo presupuestario antes de que puedan implementarse las recomendaciones para tratamiento del riesgo y de que pueda evaluarse su eficacia antes de la siguiente evaluación rutinaria de riesgos. En estos casos, se deberían programar las evaluaciones de riesgos:

a) Para que formulen sus recomendaciones para tratamiento del riesgo a tiempo para la solicitud de financiamiento.

b) Para reevaluarse tras los resultados de las asignaciones presupuestarias.

c) Para realizar la siguiente evaluación rutinaria, una vez aplicadas las recomendaciones, después de cualquier actividad de adquisición.

9.2 Ejecución del proceso de tratamiento del riesgo para la seguridad de la información

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 8.3.

Insumo: riesgos valorados.

Acción: el proceso de tratamiento del riesgo debería realizarse de acuerdo con lo descrito en el numeral 8.

Desencadenante: la necesidad de la organización de tratar los riesgos, a intervalos programados o en función de los eventos.

Resultado: riesgos residuales retenidos o aceptados.

Orientación para la implementación:

El numeral 8.3 de la NTC-ISO/IEC 27001:2022 especifica los requisitos para que las organizaciones implementen sus planes de tratamiento del riesgo. Las consideraciones contenidas en el numeral 8.6 también son pertinentes para este subnumeral.

10 APROVECHAMIENTO DE LOS PROCESOS RELACIONADOS CON EL SGSI

10.1 Contexto de la organización

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 4.

I**nsumo**: información sobre la organización y su contexto interno y externo.

Acción: se deberían considerar todos los datos pertinentes para identificar y describir las cuestiones internas y externas que influyen en la gestión de los riesgos para la seguridad de la información y los requisitos de las partes interesadas.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Desencadenante: la NTC-ISO/IEC 27001:2022 especifica los requisitos de dicha información para poder establecer objetivos de seguridad de la información.

Resultado: cuestiones internas y externas relacionadas con el riesgo que afectan la gestión del riesgo para la seguridad de la información.

Orientación para la implementación:

La organización debería tener una comprensión de alto nivel (por ejemplo, estratégica) de las cuestiones importantes que pueden afectar al SGSI, ya sea positiva o negativamente. Además, debería conocer el contexto interno y externo que es relevante para su propósito y que afecta a su capacidad para lograr los resultados previstos de su SGSI. Los resultados previstos deberían garantizar la preservación de la confidencialidad, la integridad y la disponibilidad de la información, mediante la aplicación del proceso de gestión de riesgos y el conocimiento de los riesgos que se gestionan adecuadamente.

Para identificar los riesgos de forma fiable, la organización debería comprender con suficiente detalle las circunstancias en las que opera. Esto significa que la organización debería recopilar información con respecto al contexto interno y externo de la organización, sus partes interesadas y sus requisitos (véanse los numerales 4.1 y 4.2 de la NTC-ISO/IEC 27001:2022). La recopilación de esta información debería realizarse antes de que la organización intente evaluar sus riesgos para la seguridad de la información o, de hecho, cualquier otro riesgo que pueda afectar al resultado previsto del SGSI (véase el numeral 6.1.1 de la NTC-ISO/IEC 27001:2022).

La organización debería considerar todas las fuentes de riesgo internas y externas. Es de gran relevancia que la organización conozca las partes interesadas que se oponen a la organización y cuáles son sus intereses.

EJEMPLO 1 Un ejemplo de parte interesada con intereses opuestos a los objetivos de la organización es el atacante. El atacante desea una organización con un nivel de seguridad débil. La organización toma en cuenta el interés de esta parte disponiendo de lo contrario (un nivel de seguridad fuerte), es decir, la organización considera posibles conflictos con los objetivos del SGSI. La organización garantiza, a través de controles eficaces de seguridad de la información, que tales intereses no se cumplan.

Las interfaces con servicios o actividades que no están completamente dentro del ámbito del SGSI deberían considerarse en la evaluación de riesgos para la seguridad de la información de la organización.

EJEMPLO 2 Un ejemplo de este tipo de situación es el uso compartido de activos (por ejemplo, instalaciones, sistemas informáticos y bases de datos) con otras organizaciones, o la subcontratación de una función empresarial.

La forma de considerar otros factores pertinentes que influyen en la seguridad de la información depende de la elección de la organización en cuanto a los métodos de identificación y análisis del riesgo.

Los objetivos de seguridad de la información de la organización (véase el numeral 6.2 de la NTC-ISO/IEC 27001:2022) pueden limitar los criterios de aceptación del riesgo (por ejemplo, el nivel aceptable de riesgo puede ser una función de las recompensas potenciales asociadas a las diferentes actividades empresariales). Adicionalmente, la política de seguridad de la información puede restringir el tratamiento del riesgo (por ejemplo, ciertas opciones de tratamiento del riesgo pueden ser excluidas por dicha política).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

10.2 Liderazgo y compromiso

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 5.1.

Insumo: información sobre los resultados de la evaluación del riesgo para la seguridad de la información o los resultados del tratamiento del riesgo para la seguridad de la información que requieran aprobación o apoyo.

Acción: el nivel apropiado de la dirección debería considerar los resultados relacionados con los riesgos para la seguridad de la información, para decidir respecto a o apoyar acciones adicionales.

Desencadenante: la NTC-ISO/IEC 27001 requiere que el nivel adecuado de la dirección participe en todas las actividades relacionadas con los riesgos para la seguridad de la información.

Resultado: aprobación o apoyo relacionados con los riesgos para la seguridad de la información.

Orientación para la implementación:

La alta dirección rinde cuentas sobre la gestión de los riesgos y debería dirigir e impulsar las evaluaciones de riesgos, lo que comprende:

- Garantizar que se asignen los recursos necesarios a la gestión de riesgos.
- Asignar autoridad, responsabilidad y rendición de cuentas a los niveles adecuados dentro de la organización en lo que respecta a la gestión de riesgos.
- La comunicación con las partes interesadas.

10.3 Comunicación y consulta

NOTA 1 Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 7.4.

NOTA 2 La NTC-ISO/IEC 27001 se refiere directamente a la parte de comunicación de esta actividad.

Insumo: información sobre los riesgos, sus causas, consecuencias y su probabilidad, definidos a través de los procesos de gestión de riesgos.

Acción: la información sobre los riesgos, sus causas, sus consecuencias, su probabilidad y los controles que se adoptan para tratarlos debería comunicarse a las partes interesadas externas e internas, o bien obtenerse de ellas.

Desencadenante: la NTC-ISO/IEC 27001 requiere esta comunicación.

Resultado: la percepción y comprensión continua, por las partes interesadas pertinentes, del proceso y los resultados de la gestión de riesgos para la seguridad de la información de la organización.

Orientación para la implementación:

La actividad de comunicación y consulta pretende lograr un acuerdo sobre cómo gestionar los riesgos mediante el intercambio y/o la distribución de información sobre los riesgos con los propietarios de los riesgos y otras partes interesadas pertinentes. La información incluye, entre otros aspectos, la existencia, la naturaleza, la forma, la probabilidad, la consecuencia, la importancia, el tratamiento y la aceptación de los riesgos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

El numeral 6.1.2, ítem c) 2), de la NTC-ISO/IEC 27001:2022, requiere que se identifiquen los propietarios de los riesgos para la seguridad de la información. La propiedad de los riesgos puede confundirse u ocultarse deliberadamente. Aunque pueda identificarse a los propietarios de los riesgos, pueden mostrarse reacios a reconocer que son responsables de los riesgos que les pertenecen, por lo que obtener su participación en el proceso de gestión de riesgos puede resultar difícil. Debería existir un procedimiento de comunicación definido para informar a los interesados sobre la propiedad del riesgo.

El numeral 6.1.3, ítem f), de la NTC-ISO/IEC 27001:2022, requiere que los propietarios de los riesgos aprueben el o los planes de tratamiento del riesgo y que decidan sobre la aceptación de los riesgos residuales. La comunicación entre los propietarios de los riesgos y el personal responsable de la implementación del SGSI es una actividad importante. Debería haber un acuerdo sobre cómo gestionar los riesgos mediante el intercambio y/o la distribución de información sobre los riesgos con los propietarios de los riesgos y, quizás, con otras partes interesadas y responsables de la toma de decisiones. La información incluye, entre otros, la existencia, la naturaleza, la forma, la probabilidad, la importancia, el tratamiento y la aceptación de los riesgos. La comunicación debería ser bidireccional.

Según la naturaleza y la sensibilidad de los riesgos, puede ser necesario limitar parte de la información sobre los riesgos, su evaluación y tratamiento a los responsables de identificarlos, evaluarlos y tratarlos, en función de la necesidad de conocimiento. La comunicación de los riesgos debería controlarse de acuerdo con la "necesidad de conocimiento", tomando en consideración el nivel de detalle requerido por diferentes partes interesadas, en consulta con los propietarios o posibles propietarios de los riesgos, con el objetivo de evitar difundir los riesgos más sensibles y sus debilidades conocidas asociadas.

Las percepciones del riesgo pueden variar debido a diferencias en los supuestos, los conceptos, las necesidades, los problemas y las preocupaciones de las partes interesadas pertinentes en lo que se refiere al riesgo o a las cuestiones sometidas a debate. Es probable que las partes interesadas emitan juicios sobre la aceptación del riesgo, según su percepción del mismo. Por esto es especialmente importante garantizar que las percepciones de riesgo de las partes interesadas, así como sus percepciones de los beneficios, se puedan identificar y documentar, y que las razones de fondo se entiendan y aborden con claridad.

La comunicación y consulta respecto a los riesgos pueden contribuir a mejorar el compromiso de las partes interesadas con lo que se está haciendo, y a que las partes interesadas pertinentes se apropien de las decisiones y los resultados. La comunicación y consulta con las partes interesadas, a medida que se desarrollan los criterios y se seleccionan los métodos de evaluación de riesgos, también puede mejorar la apropiación de los resultados por parte de las partes interesadas. Es menos probable que las partes interesadas cuestionen los resultados de los procesos que estas mismas han ayudado a diseñar. Por consiguiente, suele aumentar la probabilidad de que acepten los resultados y apoyen los planes de acción. En los casos en que las partes interesadas sean los directivos, esto puede generar el compromiso de alcanzar los objetivos de gestión de riesgos y proporcionar los recursos que sean necesarios.

La comunicación de riesgos debería llevarse a cabo con el fin de:

- Dar confianza sobre los resultados de la gestión de riesgos de la organización.
- Recopilar información sobre los riesgos.
- Compartir los resultados de la evaluación de riesgos y presentar el plan de tratamiento del riesgo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Evitar o reducir tanto la aparición como las consecuencias de las violaciones de la seguridad de la información debidas a la falta de comprensión mutua entre los propietarios de los riesgos y las partes interesadas.
- Respaldar a los propietarios de los riesgos.
- Obtener nuevos conocimientos sobre seguridad de la información.
- Coordinar con otras partes y planificar respuestas para reducir las consecuencias de cualquier incidente.
- Dar un sentido de responsabilidad a los propietarios del riesgo y a otras partes con un interés legítimo en el riesgo.
- Mejorar la concienciación.

Una organización debería desarrollar planes de comunicación de riesgos para las operaciones normales, así como para las emergencias. La actividad de comunicación y consulta de riesgos debería realizarse continuamente.

La coordinación entre los principales propietarios de los riesgos y las partes interesadas pertinentes puede lograrse mediante la formación de un comité en el que puedan debatirse los riesgos, su priorización y tratamiento adecuados, y su aceptación.

Las comunicaciones de riesgos se pueden transmitir voluntariamente a terceros externos para permitir una mejor coordinación de o concienciación sobre la gestión o respuesta a los riesgos, y, en determinadas circunstancias, también pueden requerirlas los reguladores o los socios comerciales.

Es importante cooperar con la unidad de relaciones públicas o comunicación correspondiente dentro de la organización para coordinar todas las tareas relacionadas con la comunicación de riesgos. Esto es fundamental en caso de activación de la comunicación de crisis, por ejemplo, en respuesta a incidentes específicos.

10.4 Información documentada

10.4.1 Generalidades

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 7.5.

La NTC-ISO/IEC 27001 especifica los requisitos de que las organizaciones conserven información documentada sobre el proceso de evaluación de riesgos (véase el numeral 6.1.2 de la NTC-ISO/IEC 27001:2022) y sus resultados (véase el numeral 8.2 de la NTC-ISO/IEC 27001:2022); y sobre el proceso del tratamiento del riesgo (véase el numeral 6.1.3 de la NTC-ISO/IEC 27001:2022) y sus resultados (véase el numeral 8.2 de la NTC-ISO/IEC 27001:2022).

10.4.2 Información documentada sobre los procesos

Insumo: conocimiento de los procesos definidos por la organización de evaluación de riesgos para la seguridad de la información y del tratamiento del riesgo, de acuerdo con lo dispuesto en los numerales 7 y 8.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Acción: se debería documentar y conservar información sobre los procesos de evaluación de riesgos para la seguridad de la información, y sobre el tratamiento del riesgo.

Desencadenante: la NTC-ISO/IEC 27001 requiere información documentada sobre los procesos de evaluación de los riesgos para la seguridad de la información y sobre el tratamiento del riesgo.

Resultado: información documentada requerida por las partes interesadas (por ejemplo, el organismo de certificación), o determinada por la organización como necesaria para la eficacia del proceso de evaluación de riesgos para la seguridad de la información o del proceso de tratamiento del riesgo para la seguridad de la información.

Orientación para la implementación:

La información documentada sobre el proceso de evaluación de riesgos para la seguridad de la información debería contener:

a) Una definición de los criterios de riesgo (incluidos los criterios de aceptación del riesgo y los criterios para realizar las evaluaciones de riesgos para la seguridad de la información).

b) Una justificación de la consistencia, validez y comparabilidad de los resultados.

c) Una descripción del método de identificación del riesgo (incluida la identificación de los propietarios de los riesgos).

d) Una descripción del método de análisis de los riesgos para la seguridad de la información (incluida la evaluación de las consecuencias potenciales, la probabilidad realista y el nivel de riesgo resultante).

e) Una descripción del método para comparar los resultados con los criterios de riesgo y la priorización de los riesgos para el tratamiento del riesgo.

La información documentada sobre el proceso de tratamiento del riesgo para la seguridad de la información debería contener descripciones sobre:

- El método para seleccionar las opciones adecuadas de tratamiento del riesgos para la seguridad de la información.
- El método para determinar los controles necesarios.
- Cómo se utiliza el Anexo A de la NTC-ISO/IEC 27001:2022 para determinar que los controles necesarios no se han pasado por alto inadvertidamente.
- Cómo se elaboran los planes de tratamiento del riesgo.
- Cómo se obtiene la aprobación de los propietarios del riesgo.

10.4.3 Información documentada sobre los resultados

Insumo: los resultados de la evaluación de los riesgos para la seguridad de la información y del tratamiento del riesgo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Acción: se debería documentar y conservar información sobre los resultados de la evaluación de riesgos para la seguridad de la información y del tratamiento del riesgo.

Desencadenante: la NTC-ISO/IEC 27001 requiere información documentada sobre los resultados de la evaluación de riesgos para la seguridad de la información y del tratamiento del riesgo.

Resultado: información documentada sobre los resultados de la evaluación de riesgos para la seguridad de la información y los del tratamiento.

Orientación para la implementación:

Puesto que las organizaciones están obligadas a realizar evaluaciones de riesgos a intervalos planificados, o cuando se proponen o se producen cambios significativos, al menos debería haber pruebas de que existe una programación y de que las evaluaciones de riesgos se realizan de acuerdo con dicha programación. Si se propone un cambio, o ya se ha producido, debería haber evidencias de la realización de una evaluación de riesgos asociada. En caso contrario, la organización debería explicar por qué el cambio es significativo o no.

La información documentada sobre los resultados de la evaluación de riesgos para la seguridad de la información debería contener:

a) Los riesgos identificados, sus consecuencias y su probabilidad.

b) La identidad del o de los propietarios del riesgo.

c) Los resultados de la aplicación de los criterios de aceptación del riesgo.

d) La prioridad del tratamiento del riesgo.

También se recomienda registrar la justificación de las decisiones sobre riesgos, tanto para aprender de los errores en casos concretos como para facilitar la mejora continua.

La información documentada sobre los resultados del tratamiento del riesgo para la seguridad de la información debería contener:

- La identificación de los controles necesarios.
- Cuando corresponda y esté disponible, evidencia de que estos controles necesarios actúan para modificar los riesgos, a fin de cumplir con los criterios de aceptación de riesgos de la organización.

10.5 Seguimiento y revisión

10.5.1 General

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 9.1.

El proceso de monitoreo de la organización (véase NTC-ISO/IEC 27001:2022, 9.1) debería abarcar todos los aspectos de los procesos de evaluación de riesgos y de tratamiento del riesgo, con los siguientes fines:

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

a) Garantizar que los tratamientos del riesgo son eficaces, eficientes y económicos, tanto en su diseño como en su funcionamiento.

b) Obtener información para mejorar las futuras evaluaciones de riesgos.

c) Analizar y extraer lecciones de los incidentes (incluidos los cuasi-accidentes), los cambios, las tendencias, los éxitos y los fracasos.

d) Detectar los cambios en el contexto interno y externo, incluidos los cambios en los criterios de riesgo y en los propios riesgos, los cuales pueden requerir la revisión de los tratamientos y prioridades de riesgo.

e) Identificar los riesgos emergentes.

Los escenarios de riesgos retenidos, que proceden de las actividades de gestión de riesgos, pueden trasladarse a escenarios de monitoreo para garantizar un proceso de monitoreo eficaz. Puede encontrar más información sobre los escenarios de monitoreo en el literal A.2.7.

10.5.2 Monitoreo y revisión de los factores que afectan a los riesgos

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 9.1.

Insumo: toda la información sobre riesgos que se obtiene de las actividades de gestión de riesgos.

Acción: los riesgos y sus factores (es decir, el valor de los activos, las consecuencias, las amenazas, las vulnerabilidades, la probabilidad de que se produzcan) deberían monitorearse y revisarse para identificar cualquier cambio en el contexto de la organización en una fase temprana, y para mantener una visión general del panorama completo de riesgos.

Desencadenante: revisión de la política de la organización, y la detección de cualquier cambio en el ambiente operativo o de amenazas actual.

Resultado: alineación continua de la gestión de riesgos con los objetivos empresariales de la organización y con los criterios de aceptación de riesgos.

Orientación para la implementación:

El numeral 9.1 de la NTC-ISO/IEC 27001:2022 requiere que las organizaciones valoren su desempeño en materia de seguridad de la información (y la eficacia del SGSI). De conformidad con este requisito, las organizaciones deberían utilizar su(s) plan(es) de tratamiento del riesgo como tema para sus valoraciones de desempeño. Para ello, una organización debería definir primero una o más necesidades de información, por ejemplo, para describir lo que la alta dirección desea saber sobre la capacidad de la organización para defenderse de las amenazas. A partir de esta especificación de alto nivel, la organización debería determinar las mediciones que tiene que realizar y cómo se deberían combinar para satisfacer la necesidad de información.

Los riesgos no son estáticos. Los escenarios de eventos, los valores de los activos, las amenazas, las vulnerabilidades, las probabilidades y las consecuencias pueden cambiar bruscamente, sin ninguna indicación. Se debería llevar a cabo un monitoreo constante para detectar estos cambios. Esto se puede

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

apoyar en servicios externos que proporcionen información sobre las nuevas amenazas o vulnerabilidades. Las organizaciones deberían garantizar el monitoreo continuo de factores pertinentes, como:

a) Nuevas fuentes de riesgo, incluidas las vulnerabilidades de TI informadas recientemente.

b) Nuevos activos que se han incluido en el ámbito de la gestión de riesgos.

c) Modificación necesaria de los valores de los activos (por ejemplo, debido a cambios en los requisitos empresariales).

d) Vulnerabilidades identificadas, para determinar cuáles quedan expuestas a amenazas nuevas o reemergentes.

e) Cambios en los patrones de uso de las tecnologías existentes o nuevas que puedan abrir nuevas posibles oportunidades de ataque.

f) Modificaciones legislativas y reglamentarias.

g) Cambios en el apetito por el riesgo, y percepciones de qué es aceptable ahora y qué ya no lo es.

h) Incidentes de seguridad de la información, tanto dentro como fuera de la organización.

Las nuevas fuentes de riesgo o los cambios en la probabilidad o las consecuencias pueden aumentar los riesgos previamente evaluados. La revisión de los riesgos bajos y retenidos debería examinar cada riesgo por separado, así como todos esos riesgos de forma agregada, para evaluar su posible consecuencia acumulada. Si los riesgos ya no entran en la categoría de riesgo bajo o aceptable, deberían tratarse mediante una o varias de las opciones del numeral 8.2.

Los factores que afectan a la probabilidad de que se produzcan eventos y a sus correspondientes consecuencias pueden cambiar, al igual que los factores que afectan a la idoneidad o al costo de las distintas opciones de tratamiento. Los cambios importantes que afecten a la organización deberían ser motivo para realizar una revisión más específica. Las actividades de monitoreo de riesgos se deberían repetir con regularidad, y se deberían revisar periódicamente las opciones seleccionadas para el tratamiento del riesgo.

Las nuevas amenazas o vulnerabilidades, o los cambios en la probabilidad o consecuencias, pueden aumentar los riesgos que anteriormente se consideraban bajos. La revisión de los riesgos bajos y retenidos debería considerar cada riesgo por separado, así como todos esos riesgos de forma agregada, para evaluar su posible consecuencia acumulada. Si los riesgos ya no entran en la categoría de riesgo bajo o aceptable, deberían tratarse mediante una o varias de las opciones de la numeral 8.

Los factores que afectan a la probabilidad de que se produzcan amenazas y a sus correspondientes consecuencias pueden cambiar, al igual que los factores que afectan a la idoneidad o al costo de las distintas opciones de tratamiento. Los cambios importantes que afecten a la organización deberían ser motivo para realizar una revisión más específica. Las actividades de monitoreo de riesgos deberían repetirse con regularidad, y se deberían revisar periódicamente las opciones seleccionadas para el tratamiento del riesgo.

El resultado de las actividades de monitoreo de riesgos puede ser una contribución a otras actividades de revisión de riesgos. La organización debería revisar todos los riesgos periódicamente, así como cuando se propongan o se produzcan cambios importantes, de acuerdo con lo dispuesto en el numeral 8 de la NTC-ISO/IEC 27001:2022.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

10.6 Revisión de la gestión

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 9.3.

Insumo: los resultados de las evaluaciones de riesgo para la seguridad de la información, el estado del plan de tratamiento del riesgo para la seguridad de la información.

Acción: los resultados de la evaluación de riesgos de seguridad de la información y el estado del plan de tratamiento del riesgo de seguridad de la información deberían revisarse para confirmar que los riesgos residuales cumplen con los criterios de aceptación de riesgos, y que el plan de tratamiento del riesgo aborda todos los riesgos relevantes y sus opciones de tratamiento del riesgo.

Desencadenante: como parte de la programación de las actividades de revisión.

Resultado: cambios en los criterios de aceptación de riesgos y en los criterios para realizar las evaluaciones de riesgos para la seguridad de la información; plan actualizado de tratamiento del riesgo para la seguridad de la información o SOA.

10.7 Acción correctiva

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 10.1.

Insumo: el plan de tratamiento del riesgo demuestra ser ineficaz, lo que significa que el riesgo residual se mantendrá en niveles inaceptables una vez finalizado el plan de tratamiento.

Acción: revise el plan de tratamiento del riesgo, e impleméntelo para modificar el riesgo residual hasta un nivel aceptable.

Desencadenante: la decisión de revisar el plan de tratamiento del riesgo.

Resultado: un plan de tratamiento del riesgo revisado y su implementación.

Orientación para la implementación:

Las no conformidades relacionadas con la eficacia del plan de tratamiento del riesgo se pueden plantear mediante una auditoría interna o externa, o mediante monitoreo e indicadores. El plan de tratamiento debería revisarse para reflejar:

- Los resultados del proceso de tratamiento del riesgo para la seguridad de la información.
- La implementación progresiva del plan (por ejemplo, un control se aplica según lo especificado, según lo diseñado, según lo construido).
- Las dificultades detectadas en la implementación de los controles (por ejemplo, problemas técnicos o financieros, inconsistencias con factores internos o externos como consideraciones de privacidad).

También hay casos en los que, aunque los riesgos residuales sean aceptables al finalizar el plan de tratamiento, los usuarios rechazarán su uso o intentarán eludirlo debido a que estos controles no son aceptados por los usuarios en términos de facilidad de uso (por ejemplo, no son ergonómicos, son demasiado complicados o largos).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La organización debería revisar la eficacia del plan de tratamiento revisado.

10.8 Mejora continua

NOTA Este subnumeral se refiere a la NTC-ISO/IEC 27001:2022, numeral 10.2

Insumo: toda la información sobre riesgos que se obtiene de las actividades de gestión de riesgos.

Acción: el proceso de gestión de riesgos para la seguridad de la información debería monitorearse, revisarse y mejorarse continuamente según sea necesario.

Desencadenante: la organización busca mejorar y madurar a partir de las lecciones aprendidas durante el proceso de gestión de riesgos para la seguridad de la información.

Resultado: pertinencia continua del proceso de gestión de riesgos de seguridad de la información para los objetivos empresariales de la organización o actualización del proceso.

Orientación para la implementación:

Para garantizar que el proceso de gestión de los riesgos para la seguridad de la información sea correcto, es necesario monitorear y revisar continuamente que el contexto, el resultado de la evaluación y del tratamiento del riesgo, así como los planes de gestión, sigan siendo pertinentes y adecuados a las circunstancias.

La organización debería asegurarse de que el proceso de gestión de riesgos para la seguridad de la información y las actividades relacionadas siguen siendo apropiados en las circunstancias actuales y de que se siguen. Toda mejora del proceso que se haya acordado, o las acciones necesarias para mejorar el cumplimiento del proceso, se deberían notificar a los gestores responsables. Estos gestores deberían tener la seguridad de que no se pasa por alto ni se subestima ningún riesgo o elemento de riesgo, y de que se adoptan las medidas y decisiones necesarias para proporcionar una comprensión del riesgo y una capacidad de respuesta realistas.

Se debería tener en cuenta que el proceso de gestión de cambios debería retroalimentar continuamente el proceso de gestión de riesgos, para garantizar que las variaciones en los sistemas de información capaces de modificar los riesgos se tomen en consideración oportunamente, incluso modificando las actividades de evaluación de riesgos para valorarlas adecuadamente.

Así mismo, la organización debería verificar periódicamente los criterios utilizados para medir el riesgo. Esta verificación debería garantizar que todos los elementos siguen siendo válidos y consistentes con los objetivos, estrategias y políticas del negocio, y que los cambios en el contexto del negocio se toman en consideración adecuadamente durante el proceso de gestión de riesgos de seguridad de la información. Esta actividad de monitoreo y revisión debería abordar (entre otros):

- El contexto jurídico y medioambiental.
- El contexto de competencia.
- El enfoque de la evaluación de riesgos.
- El valor y las categorías de los activos.
- Los criterios de consecuencia.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Los criterios de probabilidad.
- Los criterios de valoración del riesgo.
- Los criterios de aceptación del riesgo.
- El costo total de propiedad.
- Los recursos necesarios.

La organización debería garantizar que se dispone continuamente de recursos para la evaluación de riesgos y el tratamiento del riesgo, a fin de revisar los riesgos, abordar las amenazas o vulnerabilidades, sean nuevas o modificadas, y asesorar a la dirección en consecuencia.

El monitoreo de la gestión de riesgos puede conllevar la modificación o ampliación del enfoque, de la metodología o de las herramientas utilizadas, de acuerdo con:

- La madurez de riesgo de la organización.
- Los cambios identificados.
- La iteración de la evaluación de riesgos.
- El objetivo del proceso de gestión de riesgos para la seguridad de la información (por ejemplo, la continuidad del negocio, la resistencia a los incidentes, la conformidad).
- El objeto del proceso de gestión de riesgos para la seguridad de la información (por ejemplo, la organización, la unidad de negocio, el proceso de información, su implementación técnica, la aplicación, la conexión a Internet).

Los ciclos de gestión de riesgos correspondientes al campo de aplicación de la evaluación y el tratamiento del riesgo se presentan en el numeral 5.2.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

ANEXO A
(Informativo)

EJEMPLOS DE TÉCNICAS DE APOYO AL PROCESO DE EVALUACIÓN DE RIESGOS

A.1 CRITERIOS DE RIESGO PARA LA SEGURIDAD DE LA INFORMACIÓN

A.1.1 Criterios relacionados con la evaluación de riesgos

A.1.1.1 Consideraciones generales sobre la evaluación de riesgos

Generalmente, la incertidumbre personal domina la evaluación del riesgo de información, y diferentes analistas muestran distintas tendencias a la incertidumbre a la hora de interpretar los puntos de las escalas de probabilidad y consecuencia. Las escalas de referencia deberían relacionar las categorías de consecuencia, probabilidad y riesgo como valores objetivos, comunes y especificados sin ambigüedades, posiblemente expresados en términos como pérdidas financieras, en unidades monetarias y con frecuencia teórica de ocurrencia en un periodo finito, que son específicos para el enfoque cuantitativo.

Especialmente cuando se adopta el enfoque cualitativo, los analistas de riesgos deberían recibir formación sobre y practicar periódicamente con una escala de referencia de anclaje, para mantener la calibración de su juicio.

A.1.1.2 Enfoque cualitativo

A.1.1.2.1 Escala de consecuencias

La Tabla A.1 presenta un ejemplo de escala de consecuencias.

Tabla A.1. Ejemplo de escala de consecuencias

Consecuencias	Descripción
5. Catastrófico	**Consecuencias sectoriales o normativas más allá de la organización** Impacto sustancial en el o los ecosistemas del sector, con consecuencias que pueden ser duraderas. Y/o: dificultad, e inclusive incapacidad, para el Estado de asegurar una función normativa o una de sus misiones de vital importancia. Y/o: consecuencias críticas sobre la seguridad de las personas y los bienes (crisis de salud, contaminación medioambiental importante, destrucción de infraestructuras esenciales, entre otras).
4. Crítico	**Consecuencias desastrosas para la organización** Incapacidad de la organización para garantizar total o parcialmente su actividad, con posibles consecuencias graves para la seguridad de las personas y los bienes. Lo más probable es que la organización no supere la situación (su continuidad está amenazada), los sectores de actividad o los sectores estatales en los que opera probablemente se verán ligeramente afectados, sin consecuencias duraderas.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Consecuencias	Descripción
3. Grave	**Consecuencias importantes para la organización** Alta degradación en el desempeño de la actividad, con posibles consecuencias importantes sobre la seguridad de las personas y los bienes. La organización superará la situación con grandes dificultades (funcionamiento en modo muy degradado), sin impacto sectorial o estatal.
2. Significativo	**Consecuencias significativas, aunque limitadas, para la organización** Degradación en el desempeño de la actividad, sin consecuencias sobre la seguridad de las personas y los bienes. La organización superará la situación a pesar de algunas dificultades (funcionamiento en modo degradado).
1. Menor	**Consecuencias insignificantes para la organización** No tiene consecuencias sobre las operaciones o el desarrollo de la actividad, ni sobre la seguridad de las personas y los bienes. La organización superará la situación sin grandes dificultades (se consumirán los márgenes).

A.1.1.2.2 Escala de probabilidades

La Tabla A.2 y la Tabla A.4 presentan ejemplos de formas alternativas de representar escalas de probabilidad. La probabilidad se puede expresar en términos probabilísticos, como en la Tabla A.2, o en términos frecuentistas, como en la Tabla A.4. La representación probabilística muestra la probabilidad promedio de que se produzca un evento de riesgo en un periodo determinado, mientras que la representación frecuentista muestra el número promedio de veces que se espera que se produzca el evento de riesgo en un periodo determinado. Dado que ambos enfoques se limitan a expresar lo mismo desde dos perspectivas diferentes, cualquiera de las dos representaciones puede utilizarse, en función de la que la organización considere más conveniente para una categoría de riesgos determinada.

Sin embargo, si ambos enfoques se utilizan como alternativas dentro de la misma organización, es importante que cada rango teóricamente equivalente en ambas escalas represente la misma probabilidad real. En caso contrario, los resultados de la evaluación dependerán de la escala utilizada y no de la probabilidad real de la fuente de riesgo evaluada. Si se utilizan ambos enfoques, el nivel probabilístico de cada rango teórico debería calcularse matemáticamente a partir del valor frecuentista del rango equivalente o viceversa, en función del enfoque que se utilice para definir la escala primaria.

Si únicamente se utiliza uno de los dos enfoques, no es necesario que los incrementos de la escala estén tan estrechamente definidos, ya que la priorización de las probabilidades se pueda seguir logrando, independientemente de los valores absolutos utilizados. Aunque la Tabla A.2 y la Tabla A.4 utilizan incrementos y rangos de probabilidad completamente diferentes, según el contexto de la organización y la categoría de riesgo que se esté evaluando, cualquiera de ellas puede ser igualmente eficaz para el análisis si se utiliza exclusivamente. No obstante, no podrían utilizarse con seguridad como alternativas en el mismo contexto, ya que los valores atribuidos a clasificaciones equivalentes no se correlacionan.

Las categorías y valores utilizados en la Tabla A.2 y la Tabla A.4 son únicamente ejemplos. El valor más apropiado para asignar a cada nivel de probabilidad varía en función del perfil de riesgo y del apetito de riesgo de la organización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.2. Ejemplo de escala de probabilidad

Probabilidad	Descripción
5. Casi seguro	La fuente de riesgo alcanzará con toda seguridad su objetivo a través de uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es muy alta.
4. Muy probable	La fuente de riesgo probablemente alcanzará su objetivo a través de uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es alta.
3. Probable	La fuente de riesgo puede alcanzar su objetivo a través de uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es significativa.
2. Bastante improbable	La fuente de riesgo tiene relativamente pocas posibilidades de alcanzar su objetivo a través de uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es baja.
1. Improbable	La fuente de riesgo tiene muy pocas posibilidades de alcanzar su objetivo a través de uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es muy baja.

Etiquetas verbales como "bajo", "medio" y "alto" se pueden asignar a las clasificaciones cuando se utiliza cualquiera de los enfoques de la evaluación de la probabilidad. Pueden ser útiles al discutir los niveles de probabilidad con partes interesadas que no sean especialistas en riesgos. Sin embargo, son subjetivos y, por tanto, inevitablemente ambiguos. Por este motivo no deberían utilizarse como descriptores primarios a la hora de realizar evaluaciones o informar al respecto.

A.1.1.2.3 Nivel de riesgo

La utilidad de las escalas cualitativas y la consistencia de las evaluaciones de riesgos que se derivan de ellas dependen totalmente de la consistencia con la que todas las partes interesadas interpreten las etiquetas de las categorías. Los niveles de cualquier escala cualitativa deberían ser inequívocos, sus incrementos deberían estar claramente definidos, las descripciones cualitativas de cada nivel deberían expresarse en un lenguaje objetivo, y las categorías no deberían traslaparse entre sí.

Por consiguiente, al utilizar descriptores verbales de probabilidad, consecuencia o riesgo, éstos deberían referirse formalmente a escalas inequívocas, ancladas a puntos de referencia numéricos (como en la Tabla A.4) o radiométricos (como en la Tabla A.2). Todas las partes interesadas deberían conocer las escalas de referencia, para garantizar que la interpretación de los datos y resultados de la evaluación cualitativa sea consistente.

La Tabla A.3 presenta un ejemplo del enfoque cuantitativo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.3. Ejemplo de enfoque cualitativo para los criterios de riesgo

Probabilidad	Consecuencia				
	Catastrófica	**Crítica**	**Grave**	**Significativa**	**Menor**
Casi seguro	Muy alto	Muy alto	Alto	Alto	Medio
Muy probable	Muy alto	Alto	Alto	Medio	Bajo
Probable	Alto	Alto	Medio	Bajo	Bajo
Bastante improbable	Medio	Medio	Bajo	Bajo	Muy bajo
Improbable	Bajo	Bajo	Bajo	Muy bajo	Muy bajo

El diseño de una matriz cualitativa de riesgos debería guiarse por los criterios de aceptación de riesgos de la organización (véase el numerales 6.4.2 y el literal A.1.2).

EJEMPLO Una organización a veces se preocupa más por las consecuencias extremas, a pesar de su improbable ocurrencia, o principalmente por los sucesos de alta frecuencia con consecuencias menores.

Al diseñar una matriz de riesgos, bien sea cualitativa o cuantitativa, el perfil de riesgo de una organización suele ser asimétrico. Los eventos triviales son por lo general los más frecuentes, y la frecuencia esperada suele disminuir a medida que aumentan las consecuencias, para culminar en probabilidades muy bajas para consecuencias extremas. Tampoco es frecuente que la exposición empresarial representada por un evento de alta probabilidad/bajas consecuencias, sea equivalente a la que representa un evento de baja probabilidad/altas consecuencias. Aunque una matriz de riesgo simétrica sobre su diagonal de bajo/bajo a alto/alto puede parecer fácil de crear y considerarse inocentemente aceptable, es poco probable que represente con exactitud el perfil de riesgo real de una organización y, por tanto, puede generar resultados erróneos. Para garantizar que una matriz de riesgos sea realista y pueda cumplir con el requisito de mejora continua (véase el numeral 10.2 de la NTC-ISO/IEC 27001:2022), la justificación para asignar cada categoría a las escalas de probabilidad y consecuencia y a la matriz de riesgos, así como el modo en que las categorías concuerdan con el perfil de riesgo de la organización, deberían documentarse al definir o modificar las escalas y la matriz. Como mínimo, se deberían describir las incertidumbres intrínsecas al uso de matrices de escala incremental, con las precauciones debidas para sus usuarios.

La utilidad de las escalas cualitativas y la consistencia de las evaluaciones de riesgos que se derivan de ellas dependen totalmente de la consistencia con la que todas las partes interesadas interpreten las etiquetas de las categorías. Los niveles de cualquier escala cualitativa deberían ser inequívocos, sus incrementos deberían estar claramente definidos, las descripciones cualitativas de cada nivel deberían expresarse en un lenguaje objetivo, y las categorías no deberían traslaparse entre sí.

A.1.1.3 Enfoque cuantitativo

A.1.1.3.1 Escalas finitas

El nivel de riesgo se puede calcular utilizando cualquier método y teniendo en cuenta todos los factores pertinentes, pero generalmente se muestra al multiplicar la probabilidad por la consecuencia.

La probabilidad representa la probabilidad matemática o frecuencia de que se produzca un evento en un plazo determinado. Este plazo suele ser anual (por año), pero puede ser tan amplio (por ejemplo, por siglo) o reducido (por ejemplo, por segundo) como lo desee la organización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Las escalas de probabilidad deberían definirse en términos prácticos, que reflejen el contexto de la organización, de modo que le ayuden a gestionar el riesgo y que sean fáciles de entender para todas las partes interesadas. Esto significa, en primer lugar, establecer límites realistas a la gama de probabilidades representadas. Si los límites máximo y mínimo de la escala están demasiado alejados, cada categoría en ella incluye una gama excesivamente amplia de probabilidades, lo que hace que la evaluación sea incierta.

EJEMPLO 1 El punto finito de probabilidad más alto de la escala puede definirse útilmente en términos del tiempo que la organización generalmente se demora en responder a los acontecimientos, y el punto finito más bajo en términos de la duración de la planificación estratégica a largo plazo de la organización.

Las probabilidades por encima y por debajo de los límites definidos de la escala pueden expresarse útilmente como "mayor que el máximo de la escala" y "menor que el mínimo de la escala", lo que indica claramente que las probabilidades más allá de los límites de la escala definida son casos extremos, que se considerarán excepcionalmente (posiblemente mediante criterios especiales para casos "fuera de los límites"). Al margen de estos límites, la probabilidad concreta es menos importante que el hecho de que sea una excepción en la dirección dada.

Por lo general, es útil medir la consecuencia utilizando una cifra financiera, ya que esto permite la agregación para la notificación del riesgo.

EJEMPLO 2 Las escalas de consecuencias monetarias normalmente se basan en factores de 10 (100 a 1 000; 1 000 a 10 000, así sucesivamente).

Las amplitudes de las categorías de una escala de probabilidad se deberían seleccionar con referencia a las de la escala de consecuencia elegida para evitar un rango excesivo de riesgo que caiga en cada categoría.

EJEMPLO 3 Si la probabilidad y la consecuencia están representadas por los índices de una escala exponencial (es decir, los logaritmos de los valores de la escala), éstos deberían sumarse.

El valor del riesgo puede calcularse de la siguiente manera: antilog [log (valor de probabilidad) + log (valor de consecuencia)].

Tabla A.4. Ejemplo de escala de probabilidad logarítmica

Frecuencia promedio aproximada	Expresión logarítmica	Valor de escala
Cada hora	(Aproximadamente 10^5)	5
Cada 8 horas	(Aproximadamente 10^4)	4
Dos veces por semana	(Aproximadamente 10^3)	3
Una vez al mes	(Aproximadamente 10^3)	2
Una vez al año	(10^1)	1
Una vez por década	(10^0)	0

EJEMPLO 4 En la Tabla A.4, un ejemplo de evento de alta frecuencia sería un ataque con contraseña asistido por computadores, o un ataque distribuido de denegación de servicio desde una red de robots. Efectivamente, las frecuencias de ataque pueden ser mucho mayores.

EJEMPLO 5 En la Tabla A.4, ejemplo de evento de baja frecuencia son las erupciones volcánicas. Aunque se prevea que un evento ocurrirá solamente una vez por siglo, eso no significa que no vaya a ocurrir durante la vida de un SGSI.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La Tabla A.5 presenta un ejemplo de escala logarítmica de consecuencias. Una de las finalidades que persigue la consideración de la frecuencia es garantizar que las medidas de protección sean lo suficientemente sólidas como para resistir secuencias de ataque de alta frecuencia, incluso cuando la probabilidad de que se produzca dicha secuencia de ataque sea baja.

Tabla A.5 - Ejemplo de escala logarítmica de consecuencias

Consecuencia (pérdida de)	Expresión logarítmica	Valor de escala
£1 000 000	(10^6)	6
£100 000	(10^5)	5
£10 000	(10^4)	4
£1 000	(10^3)	3
£100	(10^2)	2
Menos de £100	(10^1)	1

Si ambas escalas de probabilidad y consecuencia utilizan una base logarítmica de 10 para asignar el nivel, los analistas de riesgos pueden acabar con demasiados riesgos en el mismo nivel de riesgo, y pueden ser incapaces de tomar una decisión adecuada de priorización o de inversión en seguridad. En ese caso, puede ser conveniente reducir la base y aumentar el número de niveles considerados. Debería considerarse que, si se eligen bases diferentes para la probabilidad y las consecuencias, no puede aplicarse una fórmula útil para sumar dos factores.

EJEMPLO 6 Cuando se duplica la probabilidad al pasar de un nivel al siguiente, mientras que la consecuencia es 10 veces más cara, la fórmula dará como resultado los riesgos a) y b), en los que el riesgo b) tiene un nivel de consecuencia 10 veces más caro que el riesgo a), pero con solo la mitad de la probabilidad que el riesgo a), y que acaben en el mismo nivel de riesgo. Esto es económicamente incorrecto.

En la Tabla A.4 y la Tabla A.5 se relacionan rangos de probabilidad y consecuencia que cubren la mayoría de las eventualidades en organizaciones muy diferentes. No es probable que una sola organización se encuentre con la variedad de riesgos representada por la totalidad de estas escalas de ejemplo. El contexto de la organización y el campo de aplicación del SGSI deberían utilizarse para definir límites superiores e inferiores realistas, tanto para las probabilidades como para las consecuencias, teniendo en cuenta que cuantificar rangos de riesgo superiores a 1 000 a 1 probablemente tenga un valor práctico limitado.

A.1.2 Los criterios de aceptación del riesgo.

El criterio de aceptación del riesgo puede ser tan solo un valor por encima del cual los riesgos se consideran inaceptables.

EJEMPLO 1 En la Tabla A.3, si se elige el valor medio, todos los riesgos con un valor muy bajo, bajo o medio se considerarían aceptables para la organización, y todos los riesgos con un valor alto o muy alto se considerarían inaceptables.

Mediante el uso de una matriz de riesgo codificada por colores que refleje las escalas de consecuencia y probabilidad, las organizaciones pueden presentar gráficamente la distribución del riesgo a partir de una o varias evaluaciones de riesgos. Una matriz de riesgo de este tipo también se puede utilizar para señalar la actitud de la organización ante los valores de riesgo e indicar si un riesgo normalmente debería aceptarse o tratarse.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

EJEMPLO 2 Se puede aplicar una matriz de riesgo que utilice tres colores, por ejemplo, rojo, ámbar y verde, para representar los tres grados de valoración del riesgo, como se presenta en la Tabla A.6.

Puede ser beneficioso elegir otros modelos utilizando colores para una matriz de riesgos.

EJEMPLO 3 Si se utiliza una matriz de riesgos para comparar los resultados de una evaluación de riesgos realizada originalmente con los resultados de una nueva evaluación para los mismos riesgos, la reducción del riesgo puede presentarse más fácilmente si se aplican más colores a los niveles de riesgo presentes.

También es posible agregar al modelo la determinación de qué nivel de gestión está autorizado a aceptar un riesgo mediante un valor de riesgo determinado.

La Tabla A.6 presenta un ejemplo de escala de valoración.

Tabla A.6. Ejemplo de escala de valoración combinada con matriz de riesgo de tres colores

Nivel de riesgo	Valoración del riesgo	Descripción
Bajo (verde)	Aceptable tal como está	El riesgo puede aceptarse sin más medidas.
Moderado (ámbar)	Tolerable si se controla	Se debería realizar un seguimiento en términos de gestión de riesgos y se deberían establecer las acciones pertinentes en el marco de la mejora continua a medio y largo plazo.
Alto (rojo)	Inaceptable	Es absolutamente necesario tomar medidas que reduzcan el riesgo a corto plazo. De lo contrario, se debería rechazar toda o parte de la actividad.

A.2 TÉCNICAS PRÁCTICAS

A.2.1 Componentes del riesgo para la seguridad de la información

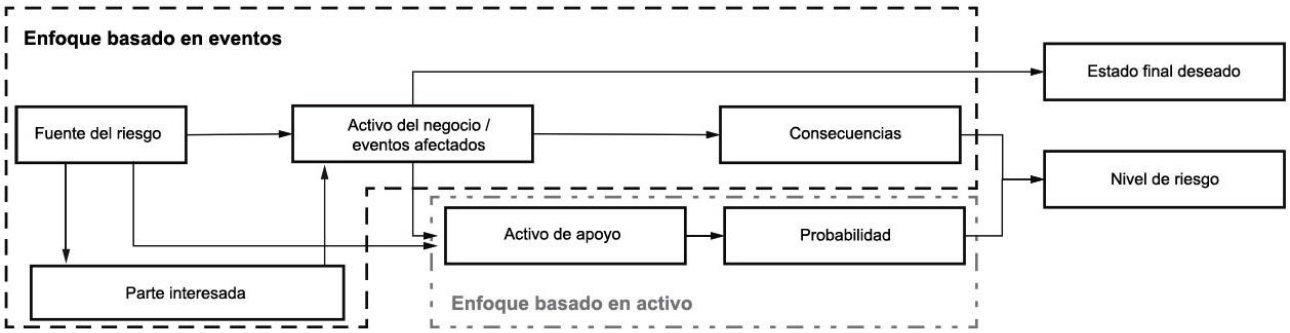
A la hora de identificar y evaluar los riesgos para la seguridad de la información, se deberían tomar en consideración los siguientes componentes:

- Componentes relacionados con el pasado:
  - Eventos e incidentes de seguridad (tanto dentro como fuera de la organización).
  - Fuentes de riesgo.
  - Vulnerabilidades aprovechadas.
  - Consecuencias medidas.
- Componentes relacionados con el futuro:
  - Amenazas.
  - Vulnerabilidades.
  - Consecuencias.
  - Escenarios de riesgo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Las relaciones entre los componentes del riesgo para la seguridad de la información se presentan en la Figura A.1 y se analizan en los anexos A.2.2 al A.2.7.



LEYENDA

→ Amenaza

Figura A.1. Componentes de la evaluación del riesgo para la seguridad de la información

Puede encontrar más información sobre el “Estado final deseado” en el literal A.2.3, entrada b).

A.2.2 Activos

Al aplicar el enfoque basado en activos a la identificación de riesgos, se deberían identificar los activos.

En el proceso de evaluación de riesgos, dentro del desarrollo de escenarios de riesgo, la identificación de eventos, consecuencias, amenazas y vulnerabilidades debería vincularse a los activos.

En el proceso de tratamiento del riesgo, cada control se aplica a un subconjunto de los activos.

Los activos se pueden dividir en dos categorías:

- Activos primarios/empresariales: información o procesos con valor para una organización.
- Activos de apoyo: componentes del sistema de información en los que se basan uno o varios activos empresariales.

Los activos primarios/empresariales se utilizan generalmente en el enfoque basado en eventos (identificación de eventos y sus consecuencias sobre los activos de negocio).

Los activos de apoyo se utilizan generalmente en el enfoque basado en activos (identificación y análisis de vulnerabilidades y amenazas sobre estos activos) y en el proceso de tratamiento del riesgo (especificación de los activos a los que se debería aplicar cada control).

Los activos empresariales y de apoyo están relacionados, por lo que las fuentes de riesgo identificadas para los activos de apoyo pueden afectar a los activos empresariales.

Por este motivo, es importante identificar las relaciones entre los activos y comprender el valor que tienen para la organización. Una estimación errónea del valor de los activos puede conducir a una

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

estimación errónea de las consecuencias relacionadas con el riesgo, pero también puede afectar a la comprensión de la probabilidad de las amenazas consideradas.

EJEMPLO 1 Un activo de apoyo aloja un activo empresarial (información en este caso).

Los datos se protegen mediante controles internos y externos, con el fin de evitar que una fuente de riesgo alcance su objetivo relacionado con el activo empresarial al aprovechar una vulnerabilidad en el activo de apoyo. Al establecer una distinción entre los tipos de activos, se deberían documentar las dependencias entre activos y evaluar la propagación del riesgo, de modo que se pueda documentar que el mismo riesgo no se evalúa dos veces, una cuando se produce en el activo de apoyo y otra cuando afecta a los activos primarios. Los gráficos de dependencia de activos son herramientas útiles que permiten representar dichas dependencias y garantizar que se han considerado todas ellas.

EJEMPLO 2: El gráfico que se presenta en la Figura A.2 indica los activos dependientes para el activo empresarial "mostrar procesamiento de pedidos y facturas" y puede leerse de la siguiente manera:

- "Administrador" (tipo: recurso humano), quien, si no recibe la formación adecuada, propaga un riesgo hacia el activo.
- "Mantenimiento informático" (tipo: servicio), que propaga el riesgo hacia el activo.
- "Servidor" (tipo: *hardware*) o al activo "Red" (tipo: conectividad de red). El servidor, si deja de funcionar, o la red mal configurada que provoca el activo.
- "Portal web" (tipo: aplicación), que deje de funcionar o no esté disponible.

Sin el "portal web", el proceso empresarial "mostrar procesamiento de pedidos y facturas" no ofrece el proceso previsto a los clientes.

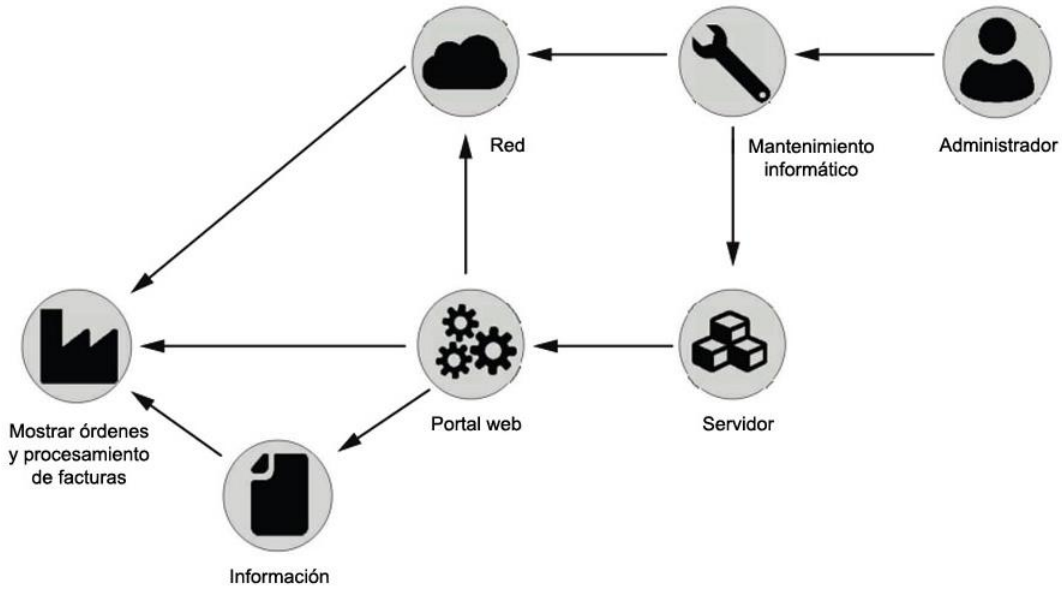


Figura A.2. Ejemplo de gráfico de dependencia de activos

A.2.3 Fuentes de riesgo y estado final deseado

Este literal propone caracterizar este tipo de fuentes de riesgo. Dos criterios principales estructuran este enfoque descriptivo:

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- La motivación.
- La capacidad de actuar.

a) Identificación de la fuente de riesgo.

La Tabla A.7 presenta ejemplos y métodos clásicos de ataque

Tabla A.7. Ejemplos y métodos clásicos de ataque

Fuente de riesgo	Ejemplos y métodos clásicos de ataque
Relacionados con el Estado	Estados, agencias de inteligencia Método: ataques realizados generalmente por profesionales, que trabajan con un calendario y un método de ataque preestablecidos. Este perfil de atacante se caracteriza por su capacidad para llevar a cabo una operación ofensiva durante un largo periodo de tiempo (recursos estables, procedimientos) y para adaptar sus herramientas y métodos a la topología del objetivo. Por extensión, estos actores cuentan con los medios para adquirir o descubrir vulnerabilidades de día 0, y algunos son capaces de infiltrarse en redes aisladas y realizar ataques sucesivos para alcanzar uno o varios objetivos (por ejemplo, mediante un ataque dirigido a la cadena de suministro).
Crimen organizado	Organizaciones cibercriminales (mafias, bandas, grupos delictivos) Método: estafas en línea o presenciales, petición de rescate o ataque mediante *ransomware*, uso de redes de bots, entre otros. Debido principalmente a la proliferación de paquetes de ataque fácilmente disponibles en línea, los ciberdelincuentes llevan a cabo operaciones cada vez más sofisticadas y organizadas con fines lucrativos o fraudulentos. Algunos disponen de medios para comprar o descubrir vulnerabilidades de Día 0.
Terroristas	Ciberterroristas, cibermilicias Método: ataques que no suelen ser muy sofisticados, pero que se llevan a cabo con fines de desestabilización y destrucción: denegación de servicio (destinada, por ejemplo, a dejar fuera de servicio los servicios de urgencia de un centro hospitalario, paradas inconvenientes de un sistema industrial de producción de energía), aprovechamiento de las vulnerabilidades de sitios de Internet y desfiguración.
Activista ideológico	Ciberhacktivistas, grupos de interés, sectas Método: los métodos de ataque y la sofisticación de los ataques son relativamente similares a los de los ciberterroristas, pero su motivación es menos destructiva. Algunos actores llevan a cabo estos ataques con el fin de transmitir una ideología o un mensaje (por ejemplo, el uso masivo de las redes sociales como caja de resonancia).
Grupos especializados	Perfil de “cibermercenario” con capacidades informáticas generalmente altas desde el punto de vista técnico. Por ello, se deberían diferenciar de los *script-kiddies*, con quienes comparte el espíritu de desafío y búsqueda de reconocimiento, pero con un objetivo lucrativo. Estos grupos se pueden organizar como grupos especializados que proponen verdaderos servicios de jaqueo. Método: Este tipo de hacker experimentado suele estar en el origen del diseño y la creación de paquetes de ataque y herramientas, disponibles en línea (posiblemente previo pago), y que luego pueden ser utilizados "llave en mano" por otros grupos de atacantes. No hay otras motivaciones particulares que el beneficio económico.
Aficionado	Perfil del hacker *script-kiddies* o con buenos conocimientos informáticos; motivado por la búsqueda del reconocimiento social, la diversión o el desafío. Método: ataques básicos pero con la capacidad de utilizar paquetes de ataque que están disponibles en línea.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Fuente de riesgo	Ejemplos y métodos clásicos de ataque
Vengador	Las motivaciones de este perfil de atacante están guiadas por un espíritu de venganza aguda o un sentimiento de injusticia (por ejemplo, un empleado despedido por una falta grave, un proveedor de servicios descontento tras un contrato que no se renovó, entre otros). Método: este perfil de atacante se caracteriza por su determinación y su conocimiento interno sobre los sistemas y procesos organizativos. Esto puede hacerlo más poderoso y dotarlo de un gran poder para hacer daño.
Atacante patológico	Las motivaciones de este perfil de atacante son de naturaleza patológica u oportunista, y a menudo están guiadas por el ánimo de lucro (por ejemplo, un competidor desleal, un cliente deshonesto, un estafador o un defraudador). Método: en este caso, los atacantes disponen de una base de conocimientos informáticos que los lleva a intentar comprometer el sistema de información de su objetivo, o bien utilizan los paquetes de ataque disponibles en línea, o bien deciden subcontratar el ataque informático recurriendo a un grupo especializado. En ciertos casos, los atacantes pueden dirigir su atención hacia una fuente interna (empleado descontento, proveedor de servicios inescrupuloso) e intentan corromper a este último.

b) Modelización de la motivación de una fuente de riesgo; estado final deseado.

Existe una amplia gama de motivaciones; pueden ser políticas, financieras, ideológicas, pero también sociales o ser incluso representativas de una condición psicológica puntual o patológica.

Aunque no es posible expresar directamente una motivación, ésta se puede ilustrar a través de la intención de la fuente de riesgo, y expresarse en forma de estado final deseado (DES, por su sigla en inglés): la situación general a la que la fuente de riesgo quiere llegar tras la confrontación. Una clasificación sistemática de las situaciones, vinculadas a categorías generales de acción, puede orientar el análisis contextualizado.

La Tabla A.8 presenta un ejemplo de clasificación de las motivaciones para expresar el DES.

Tabla A.8. Ejemplo de clasificación de las motivaciones para expresar el DES

Conquistar	Captación a largo plazo de recursos o mercados económicos, obtención de poder político o imposición de valores.
Adquirir	Enfoque depredador, decididamente ofensivo, impulsado por la captación de recursos o beneficios.
Prevenir	Enfoque ofensivo para limitar las acciones de un tercero.
Mantener	Esfuerzos para mantener una situación ideológica, política, económica o social.
Defender	Adopción de una postura de repliegue estrictamente defensiva, o de una actitud explícitamente amenazadora (por ejemplo, intimidación), para impedir el comportamiento agresivo de un adversario claramente designado o para impedir su acción frenándolo, entre otras medidas.
Sobrevivir	Proteger una entidad a cualquier precio, lo que puede llevar a acciones extremadamente agresivas

c) Objetivos previstos

Para alcanzar el DES, la fuente de riesgo se centra en uno o varios objetivos que afectan a los activos empresariales del sistema objetivo. Estos son los objetivos previstos de la fuente de riesgo.

La Tabla A.9 presenta ejemplos de objetivos previstos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.9. Ejemplos de objetivos previstos

Objetivos previstos	Descripción
Espionaje	Operación de inteligencia (estatal, económica). En muchos casos, el atacante busca una instalación a largo plazo en el sistema de información, con total discreción. Los sectores del armamento, el espacio, la aeronáutica, la farmacéutica, la energía y ciertas actividades del Estado (economía, finanzas y asuntos exteriores) son objetivos privilegiados.
Posicionamiento estratégico previo	El posicionamiento previo generalmente busca un ataque a largo plazo, sin que el objetivo final esté claramente establecido (por ejemplo, comprometer las redes de operadores de telecomunicaciones, o infiltrarse en sitios de Internet de información masiva para lanzar una operación de impacto político o económico con un fuerte eco). El compromiso repentino y masivo de computadores con el fin de formar una red de robots puede afiliarse a esta categoría.
Influencia	Operación que busca difundir información falsa o modificarla; movilizar a los líderes de opinión en las redes sociales, destruir reputaciones, revelar información confidencial, o degradar la imagen de una organización o de un Estado. Por lo general, el objetivo final es desestabilizar o modificar las percepciones.
Obstáculo para el funcionamiento	Operación de sabotaje que busca, por ejemplo, hacer que un sitio de Internet no esté disponible, provocar la saturación de la información, impedir el uso de un recurso digital, o hacer que una instalación física no esté disponible. Los sistemas industriales pueden estar especialmente expuestos y ser vulnerables a través de las redes informáticas con las que están interconectados (por ejemplo, al enviar comandos con el fin de generar daños en el *hardware* o una avería que requiera un mantenimiento a gran escala). Los ataques distribuidos de denegación de servicio (DDoS) son una técnica utilizada habitualmente para neutralizar recursos digitales.
Lucrativo	Operación que busca un beneficio financiero, directo o indirecto. Generalmente se vinculan a la delincuencia organizada: fraude en Internet, lavado de activos, extorsión o malversación, manipulación de mercados financieros, falsificación de documentos administrativos, robo de identidad, entre otros. Ciertas operaciones con ánimo de lucro pueden utilizar un método de ataque que forme parte de las categorías anteriores (por ejemplo, espionaje y robo de datos, *ransomware* para neutralizar una actividad), pero el objetivo final sigue siendo financiero.
Desafío, diversión	Operación que busca realizar una hazaña, con fines de reconocimiento social, como desafío o simplemente por diversión. Aunque el objetivo sea principalmente la diversión, sin ningún deseo particular de hacer daño, este tipo de operación puede tener graves consecuencias para la víctima.

La diferencia entre un DES y un objetivo puede ilustrarse con el ejemplo de una fuente de riesgo cuyo objetivo es ganar una negociación (DES), la cual busca robar información confidencial sobre las negociaciones a su competidor (objetivo estratégico). En ocasiones, el objetivo en cuestión (la información deseada) no se traduce finalmente en el DES.

Se puede considerar que el valor del objetivo, desde el punto de vista de la fuente de riesgo, se basa en su contribución al DES.

En términos muy generales, los objetivos de la fuente de riesgo se dividen en dos grandes clases:

- Aprovecharse de los recursos del objetivo en beneficio propio, por ejemplo, espionaje, robo, estafa, fraude, tráfico.

- Impedir que el objetivo utilice sus recursos (la confrontación es siempre relativa), por ejemplo, guerra, terrorismo, sabotaje, subversión, desestabilización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

A.2.4 Enfoque basado en eventos

A.2.4.1 Ecosistema

En un enfoque basado en eventos, los escenarios deberían construirse mediante el análisis de las diferentes vías pertinentes para las interacciones entre la organización y las partes interesadas, que forman todas ellas un ecosistema que las fuentes de riesgo pueden utilizar para llegar a los activos de la empresa y a sus DES.

Un número creciente de métodos de ataque utilizan los eslabones más vulnerables de dicho ecosistema para alcanzar sus objetivos.

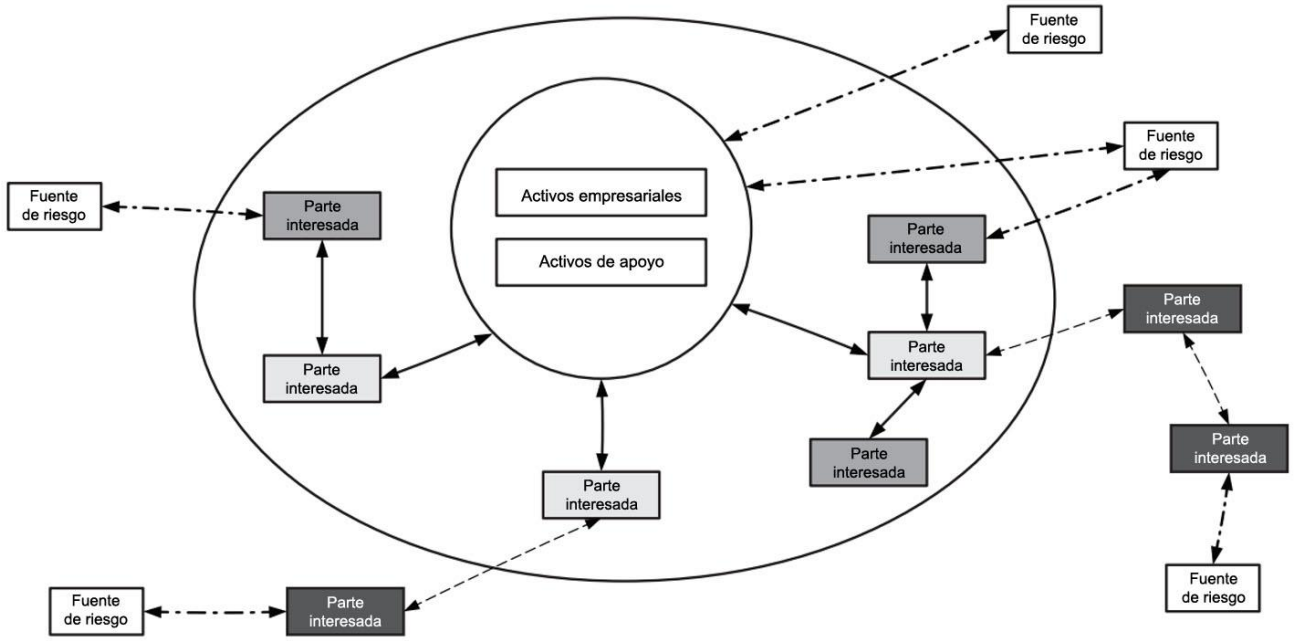
Las partes interesadas en el ámbito del SGSI que se deberían tener en cuenta al analizar los escenarios de riesgo pueden ser de dos tipos:

- Partes externas, entre las que se incluyen:
  - Clientes.
  - Socios, cocontratistas.
  - Proveedores de servicios (subcontratistas, proveedores).
- Partes internas, entre las que se incluyen:
  - Proveedores de servicios técnicos (por ejemplo, servicios de apoyo propuestos por la dirección de TI).
  - Proveedores de servicios relacionados con el negocio (por ejemplo, entidad comercial que utiliza datos comerciales).
  - Filiales (especialmente las situadas en otros países).

El objetivo de la identificación de las partes interesadas es obtener una visión clara del ecosistema, con la finalidad de identificar a las más vulnerables. La concienciación sobre ecosistemas debería abordarse como un estudio de riesgo preliminar. La Figura A.3 muestra la identificación de las partes interesadas del ecosistema.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta



SIMBOLOGÍA

←——→	Relación dentro del ecosistema		Parte interesada interna/externa directamente conectada al sistema (1er nivel de relación)
←- - -→	Relación que cruza el ecosistema		Parte interesada conectada a otra parte interesada(2do nivel de relación)
←-·-·-→	Relación dentro de la fuente de riesgo		Entidad fuera del perímetro del ecosistema

Figura A.3. Identificación de las partes interesadas del ecosistema

A.2.4.2 Escenarios estratégicos

De acuerdo con la información sobre las fuentes de riesgo y los eventos implicados, se pueden imaginar escenarios realistas de alto nivel (escenarios estratégicos), que indiquen de qué manera puede proceder una fuente de riesgo para alcanzar su DES. Por ejemplo, puede atravesar el ecosistema o desviar algunos procesos de la empresa. Estos escenarios se identifican por deducción, partiendo de las fuentes de riesgo y sus DES: para cada uno de ellos, pueden plantearse las siguientes preguntas, desde el punto de vista de la fuente de riesgo:

- ¿Cuáles son los activos de negocio de la organización a los que es muy importante que apunten las fuentes de riesgo para alcanzar su DES?

- Para hacer posible o facilitar su ataque, ¿es probable que ataquen a los interesados críticos del ecosistema que tengan acceso privilegiado a los activos de negocio?

Una vez identificados los elementos más expuestos, se puede dibujar el escenario estratégico, mediante la descripción de la secuenciación de los eventos generados por la fuente de riesgo para alcanzar su DES. La vulneración de los activos empresariales corresponde a los eventos últimos, mientras que

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

los eventos relativos al ecosistema son eventos intermedios. El escenario estratégico refleja una evaluación de las consecuencias directamente heredadas de los acontecimientos en cuestión.

Estos escenarios pueden representarse en forma de gráficos de ataque, o directamente en la vista de ecosistema del mapa del sistema de información al superponer la(s) vía(s) de ataque.

Los escenarios estratégicos requieren una consideración adicional de la probabilidad de los sucesos. El enfoque basado en activos y los escenarios operativos asociados se pueden utilizar para definir la probabilidad de los eventos. Los ejemplos de amenazas presentados en el literal A.2.5.1 se pueden utilizar para obtener las evaluaciones necesarias.

A.2.5 Enfoque basado en activo

A.2.5.1 Ejemplos de amenazas

La Tabla A.10 presenta ejemplos de amenazas clásicas. La lista se puede utilizar durante el proceso de evaluación de amenazas. Las amenazas que se consideran fuentes de riesgo pueden ser deliberadas, accidentales o medioambientales (naturales), y pueden provocar, por ejemplo, daños en o pérdida de servicios esenciales. La lista indica, para cada tipo de amenaza en el que sea pertinente, la D (deliberada), la A (accidental) o la E (de entorno). Se utiliza D para todas las acciones deliberadas dirigidas contra la información y los activos relacionados con la información; se utiliza A para todas las acciones humanas que pueden dañar accidentalmente la información y los activos relacionados con la información, y se utiliza M para todos los incidentes que no se basan en acciones humanas. Los grupos de amenazas no están en orden de prioridad.

Los controles pueden mitigar las amenazas al disuadirlas o impedir que actúen o se produzcan. La selección de controles para reducir el riesgo también requiere considerar controles de detección y de respuesta que identifiquen eventos, respondan a ellos, los contengan y se recuperen de ellos. Los controles de detección y de respuesta se asocian a las consecuencias más que a las amenazas.

EJEMPLO El registro y el monitoreo permiten identificar y responder a los eventos de seguridad.

Tabla A.10. Ejemplos de amenazas clásicas

Categoría	N°	Descripción de la amenaza	Tipo de fuente de riesgo [a]
Amenazas físicas	TP01	Fuego	A, D, E
	TP02	Agua	A, D, E
	TP03	Contaminación, radiación nociva	A, D, E
	TP04	Accidente grave	A, D, E
	TP05	Explosión	A, D, E
	TP06	Polvo, corrosión, heladas	A, D, E
Amenazas naturales	TN01	Fenómeno climático	E
	TN02	Fenómeno sísmico	E
	TN03	Fenómeno volcánico	E
	TN04	Fenómeno meteorológico	E
	TN05	Inundación	E
	TN06	Fenómeno de pandemia/epidemia	E

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Categoría	N°	Descripción de la amenaza	Tipo de fuente de riesgo [a]
Fallas en las infraestructuras	TI01	Fallas en un sistema de suministro	A, D
	TI02	Falla del sistema de refrigeración o ventilación	A, D
	TI03	Pérdida del suministro eléctrico	A, D, E
	TI04	Falla de una red de telecomunicaciones	A, D, E
	TI05	Falla del equipo de telecomunicaciones	A, D
	TI06	Radiación electromagnética	A, D, E
	TI07	Radiación térmica	A, D, E
	TI08	Impulsos electromagnéticos	A, D, E
Fallas técnica	TT01	Falla de dispositivos o sistemas	A
	TT02	Saturación del sistema de información	A, D
	TT03	Vulneración del mantenimiento del sistema de información	A, D
Acciones humanas	TH01	Atentado terrorista, sabotaje	D
	TH02	Ingeniería social	D
	TH03	Interceptación de la radiación de un dispositivo	D
	TH04	Espionaje remoto	D
	TH05	Escucha clandestina	D
	TH06	Robo de medios o documentos	D
	TH07	Robo de equipos	D
	TH08	Robo de identidad digital o de credenciales	D
	TH09	Recuperación de medios reciclados o descartados	D
	TH10	Divulgación de información	A, D
	TH11	Entrada de datos de fuentes no fiables	A, D
	TH12	Manipulación con *hardware*	D
	TH13	Manipulación con *software*	A, D
	TH14	Ataque de descarga oculta a través de Internet	D
	TH15	Ataque de repetición, ataque de intermediario	D
	TH16	Tratamiento no autorizado de datos personales	A, D
	TH17	Entrada no autorizada en instalaciones	D
	TH18	Uso no autorizado de dispositivos	D
	TH19	Uso incorrecto de dispositivos	A, D
	TH20	Daño de dispositivos o medios	A, D
	TH21	Copia ilícita de *software*	D
	TH22	Uso de *software* falsificado o copiado	A, D
	TH23	Corrupción de datos	D
	TH24	Tratamiento ilegal de datos	D
	TH25	Envío o distribución de *malware*	A, D, E
	TH26	Detección de posición	D
Compromiso de funciones o servicios	TC01	Error en el uso	A
	TC02	Abuso de derechos o permisos	A, D
	TC03	Falsificación de derechos o permisos	D
	TC04	Denegación de acciones	D

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Categoría	N°	Descripción de la amenaza	Tipo de fuente de riesgo [a]
Amenazas a la organización	TO01	Falta de personal	A, E
	TO02	Falta de recursos	A, E
	TO03	Falla de los proveedores de servicios	A, E
	TO04	Violación de la legislación o la normativa	A, D
[a] D = deliberado; A = accidental; E = medioambiental.			

A.2.5.2 Ejemplos de vulnerabilidades

La Tabla A.11 proporciona ejemplos de vulnerabilidades en diversas áreas de seguridad, así como ejemplos de amenazas que pueden aprovecharse de estas vulnerabilidades. Las listas pueden servir de ayuda durante la evaluación de amenazas y vulnerabilidades, para determinar los escenarios de riesgo pertinentes. En algunos casos, otras amenazas pueden también aprovechar estas vulnerabilidades.

Tabla A.11. Ejemplos de vulnerabilidades clásicas

Categoría	N°	Ejemplos de vulnerabilidades
Hardware	VH01	Mantenimiento insuficiente/instalación defectuosa de los medios de almacenamiento
	VH02	Programas insuficientes para el reemplazo periódico de equipos
	VH03	Susceptibilidad a la humedad, al polvo y a la suciedad
	VH04	Sensibilidad a la radiación electromagnética
	VH05	Control insuficiente de los cambios de configuración
	VH06	Susceptibilidad a las variaciones de tensión
	VH07	Susceptibilidad a las variaciones de temperatura
	VH08	Almacenamiento sin protección
	VH09	Falta de atención a la disposición final
	VH10	Copia no controlada
Software	VS01	Pruebas de *software* inexistentes o insuficientes
	VS02	Defectos conocidos en el *software*
	VS03	No se cierra la sesión al abandonar el puesto de trabajo
	VS04	Disposición o reutilización de medios de almacenamiento sin un borrado adecuado
	VS05	Configuración insuficiente de los registros para fines de auditoría
	VS06	Asignación errónea de derechos de acceso
	VS07	*Software* ampliamente distribuido
	VS08	Aplicación de programas de aplicación a datos erróneos desde el punto de vista cronológico
	VS09	Interfaz de usuario complicada
	VS10	Documentación insuficiente o inexistente
	VS11	Configuración incorrecta de los parámetros
	VS12	Fechas incorrectas
	VS13	Mecanismos insuficientes de identificación y autenticación (por ejemplo, para la autenticación de usuarios)
	VS14	Tablas de contraseñas desprotegidas
	VS15	Gestión deficiente de contraseñas
	VS16	Activación de servicios innecesarios
	VS17	Programas informáticos nuevos o inmaduros

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Categoría	N°	Ejemplos de vulnerabilidades
Software	VS18	Especificaciones poco claras o incompletas para los desarrolladores
	VS19	Control ineficiente de los cambios
	VS20	Descarga y uso de programas informáticos incontrolados
	VS21	Copias de seguridad inexistentes o incompletas
	VS22	Incumplimiento de la elaboración de informes de gestión
Red	VN01	Mecanismos insuficientes para la prueba de envío o recepción de un mensaje
	VN02	Líneas de comunicación sin protección
	VN03	Tráfico sensible sin protección
	VN04	Cableado de empalme deficiente
	VN05	Un solo punto de falla
	VN06	Ineficacia o falta de mecanismos para la identificación y autenticación del remitente y el destinatario.
	VN07	Arquitectura de red insegura
	VN08	Transferencia de contraseñas en claro
	VN09	Gestión inadecuada de la red (resiliencia del enrutamiento)
	VN10	Conexiones a redes públicas sin protección
Personal	VP01	Ausencia del personal
	VP02	Procedimientos inadecuados de contratación
	VP03	Formación insuficiente sobre seguridad
	VP04	Uso incorrecto de *software* y *hardware*
	VP05	Escasa concienciación en materia de seguridad
	VP06	Mecanismos de monitoreo insuficientes o inexistentes
	VP07	Trabajo de personal externo o de limpieza sin supervisión
	VP08	Ineficacia o falta de políticas para el uso correcto de los medios de telecomunicación y mensajería
Instalaciones	VS01	Uso inadecuado o descuidado del control de acceso físico a edificios y salas
	VS02	Ubicación en una zona susceptible de inundación
	VS03	Red de energía inestable
	VS04	Protección física insuficiente del edificio, puertas y ventanas
Organización	VO01	No se ha creado un procedimiento formal para el registro y la cancelación de usuarios, o su aplicación es ineficaz.
	VO02	No se ha creado un proceso formal de revisión (supervisión) de los derechos de acceso, o su aplicación es ineficaz.
	VO03	Disposiciones insuficientes (en materia de seguridad) en los contratos con clientes y/o con terceros.
	VO04	No se ha creado un procedimiento de monitoreo de las instalaciones de tratamiento de la información, o su aplicación es ineficaz.
	VO05	Las auditorías (supervisión) no se realizan con regularidad
	VO06	No se han creado procedimientos de identificación y evaluación de riesgos, o su aplicación es ineficaz.
	VO07	Insuficiencia o falta de informes de averías grabados en los registros del administrador y del operador.
	VO08	Respuesta inadecuada del servicio de mantenimiento
	VO09	Acuerdo de nivel de servicio insuficiente o inexistente
	VO10	No se ha creado un procedimiento de control de cambios, o su aplicación ineficaz
	VO11	No se ha creado un procedimiento formal para el control de la documentación del SGSI, o su implementación es ineficaz

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Categoría	N°	Ejemplos de vulnerabilidades
Organización	VO12	No se ha creado un procedimiento formal para la supervisión de los registros del SGSI, o su implementación es ineficaz
	VO13	No se ha creado un procedimiento formal para la autorización de información pública, o su implementación es ineficaz
	VO14	Asignación inadecuada de responsabilidades en materia de seguridad de la información
	VO15	Los planes de continuidad no existen, están incompletos o son obsoletos.
	VO16	No se ha creado una política de uso del correo electrónico, o su aplicación es ineficaz
	VO17	No se han creado procedimientos para introducir *software* en los sistemas operativos, o su aplicación es ineficaz
	VO18	No se han creado procedimientos para el tratamiento de información clasificada, o su aplicación es ineficaz.
	VO19	Las responsabilidades respecto a la seguridad de la información no están presentes en las descripciones de los cargos
	VO20	Insuficiencia o falta de disposiciones (respecto a la seguridad de la información) en los contratos con los empleados.
	VO21	No se ha definido el proceso disciplinario en caso de incidentes de seguridad de la información, o no funciona correctamente.
	VO22	No se ha creado una política formal sobre el uso de computadoras móviles, o su aplicación es ineficaz.
	VO23	Control insuficiente de los activos fuera de las instalaciones
	VO24	Insuficiencia o falta de una política de "escritorio y pantalla limpios".
	VO25	Autorización de instalaciones de tratamiento de la información no implementada o que no funciona correctamente
	VO26	Los mecanismos de monitoreo de las infracciones de seguridad no se implementan correctamente
	VO27	No se han creado procedimientos para notificar las deficiencias de seguridad, o su aplicación es ineficaz
	VO28	No se han creado procedimientos de conformidad con las disposiciones en materia de derechos intelectuales, o su aplicación es ineficaz

A.2.5.3 Métodos de evaluación de las vulnerabilidades técnicas

Se pueden utilizar métodos proactivos, como las pruebas de sistemas de información, para identificar vulnerabilidades en función de la criticidad del sistema de tecnologías de la información y la comunicación (TIC) y de los recursos disponibles (por ejemplo, fondos asignados, tecnología disponible, personas con los conocimientos necesarios para realizar la prueba). Los métodos de prueba que se utilizan incluyen:

- Herramientas automatizadas de detección de vulnerabilidades.
- Pruebas y valoración de la seguridad.
- Pruebas de penetración.
- Revisión de código.

Se utiliza una herramienta automatizada de detección de vulnerabilidades para escanear un grupo de *hosts* o una red, en busca de servicios vulnerables conocidos [por ejemplo, el sistema permite el Protocolo de Transferencia de Archivos (FTP) anónimo o el reenvío de correos]. No obstante, algunas de las vulnerabilidades potenciales identificadas por la herramienta de detección automática no

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

representan necesariamente vulnerabilidades reales en el contexto del entorno del sistema (por ejemplo, algunas de estas herramientas de detección califican las vulnerabilidades potenciales sin tener en cuenta el ambiente y los requisitos del sitio). Algunas de las vulnerabilidades señaladas por el programa de detección automática pueden no ser vulnerables para un sitio en particular, sino que pueden estar configuradas de esa manera porque su entorno así lo requiere. Por tanto, este método de prueba puede producir falsos positivos.

La prueba y valoración de la seguridad (STE, por su sigla en inglés) es otra técnica que puede utilizarse para identificar las vulnerabilidades de los sistemas de TIC durante el proceso de evaluación de riesgos. Comprende la creación y ejecución de un plan de prueba (por ejemplo, *script* de prueba, procedimientos de prueba y resultados previstos de la prueba). El objetivo de las pruebas de seguridad de sistemas es verificar la eficacia de los controles de seguridad de un sistema de TIC tal y como se han aplicado en un ámbito operativo. El objetivo es garantizar que los controles aplicados cumplan la especificación de seguridad aprobada para el *software* y el *hardware*, y que implementen la política de seguridad de la organización o que cumplan las normas del sector.

Las pruebas de penetración se pueden utilizar para complementar la revisión de los controles de seguridad y para garantizar que las diferentes facetas del sistema de TIC están protegidas. Las pruebas de penetración, cuando se utilizan en el proceso de evaluación de riesgos, pueden servir para evaluar la capacidad de un sistema de TIC para resistir intentos intencionados de burlar la seguridad del sistema. Su objetivo es probar el sistema de TIC desde el punto de vista de una fuente de amenaza e identificar potenciales fallas en los esquemas de protección del sistema de TIC.

La revisión del código es la forma más completa (pero también la más cara) de evaluar la vulnerabilidad.

Los resultados de estos tipos de pruebas de seguridad ayudan a identificar las vulnerabilidades de un sistema.

Las herramientas y técnicas de penetración pueden proporcionar resultados falsos, a menos que la vulnerabilidad se explote con éxito. Para aprovechar vulnerabilidades concretas, es necesario conocer la configuración exacta del sistema/de las aplicaciones/de los parches en el sistema probado. Si esos datos no se conocen en el momento de la prueba, no es necesariamente posible aprovechar con éxito una vulnerabilidad determinada (por ejemplo, obtener una *shell* inversa remota). Sin embargo, aún es posible bloquear o reiniciar un proceso o sistema probado. Si esto ocurre, el objeto probado también debería considerarse vulnerable.

Los métodos pueden incluir las siguientes actividades:

- Entrevistas a personas y usuarios.
- Cuestionarios.
- Inspección física.
- Análisis de documentos.

A.2.5.4 Escenarios de funcionamiento

En un enfoque basado en activos, los escenarios de funcionamiento pueden construirse analizando los diferentes caminos, entre los activos de apoyo, que las fuentes de riesgo pueden utilizar para llegar a los activos de la empresa y a sus DES.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

El análisis de estos escenarios puede ayudar a profundizar el enfoque basado en eventos.

Un ataque con éxito suele ser el resultado de aprovechar varias fallas. Los ataques intencionados suelen seguir un enfoque secuencial. Este último aprovecha, de forma coordinada, varias vulnerabilidades de carácter informático, organizativo o físico. Este enfoque, basado en el aprovechamiento simultáneo de diferentes fallas, puede tener graves consecuencias, aunque las vulnerabilidades aprovechadas pueden ser insignificantes si se consideran individualmente.

Los escenarios analizados se pueden estructurar según una secuencia de ataque típica. Existen varios modelos que se pueden utilizar [por ejemplo, el modelo *cyber chain kill* (modelo de cadena de eliminación cibernética)[1]]. El enfoque debería permitir identificar los activos de apoyo críticos que se pueden utilizar como vectores de entrada o de aprovechamiento, o como relés de propagación del ataque modelado.

Estos escenarios se pueden representar en forma de gráficos o diagramas de ataque, útiles para representar los métodos de ataque del agresor.

A.2.6 Ejemplos de escenarios aplicables en ambos enfoques

Los escenarios de riesgo se pueden construir mediante un enfoque basado en eventos, un enfoque basado en activos o con ambos.

La Figura A.4 muestra la evaluación de riesgos basada en escenarios de riesgo.

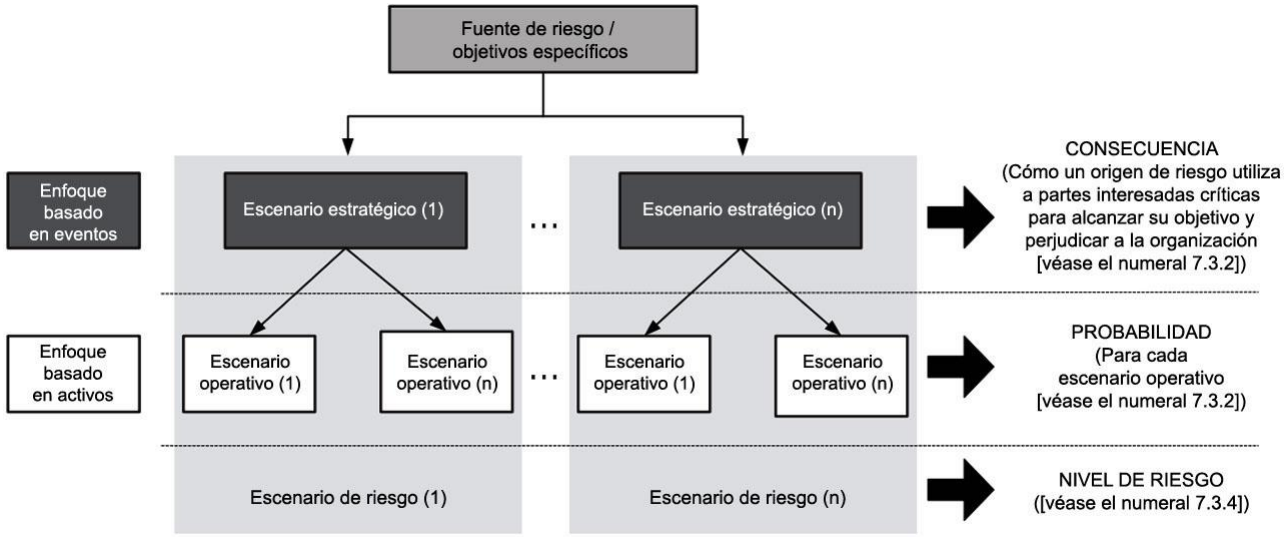


Figura A.4 Evaluación de riesgos basada en escenarios de riesgo

La Tabla A.12 muestra algunos ejemplos de escenarios de riesgo y los vínculos con los enfoques basados en activos/eventos y las fuentes de riesgo.

[1] El modelo *cyber kill chain* es el nombre comercial de un producto suministrado por Lockheed Martin. Esta información se facilita para mayor comodidad de los usuarios de este documento, y no constituye una aprobación por parte de la ISO o del ICONTEC del producto mencionado. Pueden utilizarse productos equivalentes si se puede demostrar que conducen a los mismos resultados.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.12. Ejemplos de escenarios de riesgo en ambos enfoques

Fuente de riesgo	**Objetivos previstos DES**	**Escenario estratégico de riesgo** (Enfoque basado en eventos)	**Escenario operativo de riesgo** (Enfoque basado en activo)
Estado autoritario	Adquisición de un vector de ataque estratégico	Subversión de infraestructuras críticas	Implementación de *malware* oculto y persistente en la cadena de suministro
Delincuencia organizada	Desarrollo de actividades ilegales	Explotación de infraestructuras portuarias	Infiltración del sindicato de trabajadores portuarios
			Toma de control de un sistema informatizado de gestión de flujos
		Fraude carrusel	Creación de empresas ficticias para realizar intercambios falsos en el mercado del impuesto sobre el carbono
		Extorsión	Distribución de *ransomware*
Negocios agresivos	Obtención de un monopolio de mercado	Influencia sobre el regulador	Corrupción de un responsable de la toma de decisiones
		Eliminación de competidores	Campaña de difamación en las redes sociales

A.2.7 Monitoreo de eventos relacionados con el riesgo

El monitoreo de eventos relacionados con el riesgo consiste en la identificación de los factores que pueden tener influencia en un escenario de riesgo para la seguridad de la información, como se define en el numeral 10.5.2.

En este contexto, los factores se identifican como una serie de elementos que permiten detectar un comportamiento inesperado hacia un activo determinado, y que pueden integrarse en las capacidades y herramientas de monitoreo de la organización para determinar el desencadenamiento de un escenario de riesgo para la seguridad de la información.

El monitoreo de eventos relacionados con el riesgo puede definirse mediante varios indicadores procedentes de escenarios operativos o estratégicos, ambos presentados en el numeral 7.2.1. Pueden ser de distinta naturaleza (técnicos, organizativos, de comportamiento, resultados de auditorías, entre otros). Los eventos se monitorean en función de prioridades definidas, como la magnitud de las consecuencias y la probabilidad de que se produzcan.

La Tabla A.13 presenta un ejemplo de descripción de un escenario de riesgo para la seguridad de la información, con su monitoreo asociado de eventos relacionados con el riesgo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.13. Ejemplo de escenario de riesgo y relación de monitoreo de eventos relacionados con el riesgo

Componentes del riesgo	Ejemplos		Eventos por monitorear
Escenario estratégico (basado en eventos)	Un administrador destruye documentos confidenciales		
Eventos afectados	Pérdida de documentos críticos		
Gravedad de las consecuencias	Medida descriptiva: alta		
Escenarios operativos (basados en activos)	Uso de derechos de administrador para destruir los documentos sensibles mediante el acceso directo a la base de datos	->	Detección de un acceso directo a la base de datos fuera del horario normal de trabajo
	Acceso de raíz para modificar la fecha/hora del sistema		
	Infección por *malware* de la estación de trabajo del administrador, con propagación a la base de datos.	->	Detección de operaciones que afectan a un gran volumen de datos (Destrucción)
Probabilidad	Medida descriptiva: media		
Fuente de riesgo	Administrador		
Objetivos previstos	Compromiso de la disponibilidad de documentos sensibles		
DES	Compromiso del sistema		
Controles de seguridad	Aplicación de la estrategia de copias de respaldo		
	Solución anti*malware*		
	Implementación de NTP		
	Refuerzo del sistema operativo		
	Restricción de los derechos de acceso a los datos operativos.		

El modelo fuente-función-destino-desencadenante (SFDT, por su sigla en inglés) permite construir el monitoreo de eventos relacionados con el riesgo, donde:

- Fuente: indica de dónde procede el evento/técnica (quién y por qué), y puede asociarse a los recursos descritos en el literal A.2.3
- Función: indica el tipo de evento/técnica realizados por el atacante (¿qué?).
- Destino: indica sobre qué se realiza la técnica o el evento (¿sobre qué activos de apoyo o primarios?).
- Desencadenante: indica qué condiciones permiten detectar e identificar el escenario de riesgo (resultados del ataque).

En la Figura A.5 se presenta Un ejemplo de aplicación del modelo SFDT.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

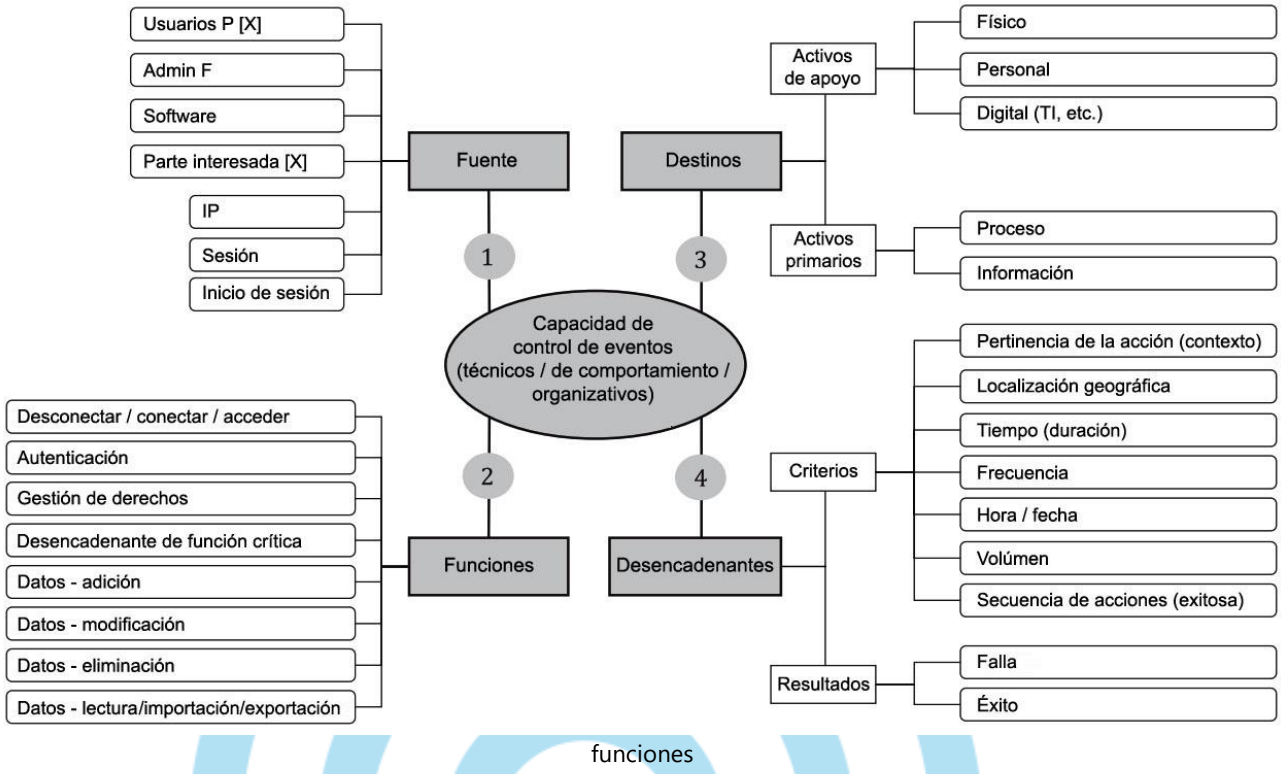


Figura A.5. Ejemplo de aplicación del modelo SFDT

Para garantizar que el monitoreo de un evento de riesgo para la seguridad de la información es efectivo y eficiente, es necesario determinar sus indicadores.

Los indicadores de monitoreo de eventos relacionados con el riesgo son:

- Nivel de riesgo del escenario de riesgo monitoreado.
- Eficacia, capacidad de los eventos relacionados con el riesgo para monitorear un escenario de riesgo.
- Eficiencia, relación entre la alerta positiva verdadera y la falsa positiva, o el costo de la caracterización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

BIBLIOGRAFÍA

[1] ISO 17666:2016, *Space systems – Risk management*

[2] ISO/IEC 27001:2022, *Information technology – Security techniques – Information security management systems - Requirements*

[3] ISO/IEC 27003, *Information technology – Security techniques – Information security management systems - Guidance*

[4] ISO/IEC 27004, Information technology – *Security techniques – Information security management - Monitoring, measurement, analysis and evaluation*

[5] ISO/IEC 27014, *Information security, cybersecurity and privacy protection – Governance of information security*

[6] ISO/IEC TR 27016, *Information technology – Security techniques – Information security management - Organizational economics*

[7] ISO/IEC 27017, *Information technology – Security techniques – Code of practice for information security controls based on ISO/IEC 27002 for cloud services*

[8] ISO/IEC 27701, *Security techniques – Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management – Requirements and guidelines*

[9] ISO 31000:2018, *Risk management – Guidelines*

[10] IEC 31010:2019, *Risk management – Risk assessment techniques*

[11] ISO Guide 73:2009*, Risk management – Vocabulary*

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

DOCUMENTO DE REFERENCIA

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. *Information security, cybersecurity and privacy protection. Guidance on managing information security risks*. Ginebra, 2022, 62 p. (ISO/IEC 27005:2022)

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La normalización fomenta la productividad, competitividad y crecimiento sostenible. Tu participación en el proceso de normalización nos permite aportar a la construcción de un mejor país. **Accede a toda la información en los siguientes portales:**

icontec

e-conecta icontec

econecta.icontec.org/

La normalización a un clic. Participa en el proceso de Normalización de manera más activa a través de nuestra plataforma e-conecta.

e-collection icontec

ecollection.icontec.org/

Información que evoluciona, conocimiento que avanza. Conoce nuestro servicio de suscripción al catálogo de normas nacionales e internacionales que tenemos para ti. Más información cdi@icontec.org

Tienda Virtual

www.tienda.icontec.org

Conoce nuestra sala de consulta virtual y las normas técnicas, publicaciones y cursos de tu interés, por medio de la tienda virtual.

CAMPUS DIGITAL

www.campus.icontecvirtual.edu.co

Conoce nuestra oferta académica y los recursos educativos gratuitos que ponemos a tu disposición para impulsar tu desarrollo.

Somos expertos en cada sector económico:



Tenemos una amplia presencia en Colombia y Latinoamérica

COLOMBIA

Apartadó
Armenia
Barranquilla
Barrancabermeja
Bogotá
Bucaramanga
Cali
Cartagena
Cúcuta
Manizales
Medellín
Montería
Ibagué
Neiva
Pereira
Pasto
Villavicencio

LATAM

Bolivia
Costa Rica
Chile
Ecuador
El Salvador
Guatemala
Honduras
México
México
Panamá
República Dominicana
Perú

Canales de atención al cliente:

Colombia: **#426**
Resto del país: **01 8000 94 9000**
cliente@icontec.org

Contamos con 60 años de trayectoria

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -
Impreso por: Consulta